CHƯƠNG 1: TỔNG QUAN CƠ SỞ LÝ THUYẾT VỀ AN TOÀN THÔNG TIN, ETHICAL HACKING VÀ MẠNG NỘI BỘ TRUYỀN THỐNG

1.1. Khái niệm cơ bản về An toàn Thông tin và Mô hình Bộ ba Bảo mật (CIA Triad)

Trong bối cảnh chuyển đổi số toàn diện và sự bùng nổ mạnh mẽ của hạ tầng kết nối mạng toàn cầu, thông tin và dữ liệu số đã trở thành tài sản chiến lược quý giá nhất của mọi cơ quan, tổ chức chính phủ cũng như các doanh nghiệp thương mại. An toàn thông tin (Cybersecurity) vì thế không chỉ đơn thuần là việc cài đặt các phần mềm diệt virus, mà là tập hợp toàn diện các công nghệ tiên tiến, các quy trình vận hành nghiêm ngặt, các chính sách bảo mật chuẩn hóa và các thực tiễn quản trị nhằm bảo vệ tuyệt đối các hệ thống mạng, thiết bị phần cứng, chương trình ứng dụng và cơ sở dữ liệu khỏi các cuộc tấn công mạng, sự cố hư hỏng hoặc hành vi truy cập trái phép.

Nền tảng lý thuyết cốt lõi của an toàn thông tin được xây dựng và định hình vững chắc dựa trên mô hình kinh điển Bộ ba bảo mật (CIA Triad):

- Tính bảo mật (Confidentiality): Đảm bảo nguyên tắc thông tin chỉ có thể được truy cập, đọc và xử lý bởi những đối tượng (người dùng hoặc tiến trình hệ thống) đã được cấp quyền hợp pháp. Tính bảo mật đóng vai trò là rào chắn ngăn chặn việc lộ lọt dữ liệu nhạy cảm ra bên ngoài qua các hình thức nghe lén mạng (sniffing) hoặc chặn bắt gói tin trái phép trên đường truyền.
- Tính toàn vẹn (Integrity): Đảm bảo sự chính xác, trọn vẹn và nhất quán của dữ liệu cũng như các phương pháp xử lý thông tin trong suốt vòng đời lưu trữ và truyền tải. Nguyên tắc này chống lại mọi hành vi chỉnh sửa, giả mạo, thêm bớt hoặc phá hoại trái phép từ các tác nhân bên ngoài lẫn nội bộ.
- Tính sẵn sàng (Availability): Đảm bảo rằng người dùng hợp pháp luôn có quyền truy cập ổn định vào thông tin và hệ thống dịch vụ bất cứ khi nào cần thiết mà không gặp phải sự gián đoạn vô cớ. Thành phần này đòi hỏi các giải pháp phòng thủ vững chắc trước các cuộc tấn công từ chối dịch vụ (DoS/DDoS) nhằm làm tê liệt hạ tầng công nghệ thông tin.

1.2. Vai trò của Hacking Đạo đức (Ethical Hacking) và Kiểm thử Xâm nhập

Trước sự gia tăng với tốc độ chóng mặt về quy mô và tính tinh vi của tội phạm mạng (black-hat hackers), các tổ chức hiện đại không thể tiếp tục duy trì các biện pháp phòng thủ bị động (reactive defense) vốn chỉ dựa vào tường lửa biên truyền thống. Ethical Hacking (Hacking đạo đức) ra đời và khẳng định vai trò như một phương pháp luận chủ động (proactive methodology), trong đó các chuyên gia an ninh mạng (white-hat hackers) vận dụng chính tư duy, công cụ, chiến thuật và kỹ thuật của tin tặc để tiến hành đánh giá, rà quét hệ thống của tổ chức nhằm phát hiện sớm các điểm yếu trước khi chúng bị lợi dụng (luôn tuân thủ các thỏa thuận pháp lý và quy tắc ứng xử - *Rules of Engagement*).

Một quy trình kiểm thử xâm nhập (Penetration Testing) tiêu chuẩn quốc tế luôn tuân thủ qua các giai đoạn tuần tự mang tính khoa học:

- Thu thập dấu vết và Trinh sát (Footprinting & Reconnaissance): Thu thập dữ liệu tình báo mã nguồn mở (OSINT), định hình mục tiêu và phác thảo bề mặt tấn công.
- Quét mạng (Scanning Networks): Tương tác chủ động với cơ sở hạ tầng mạng để xác định các máy chủ đang trực tuyến (live hosts), danh sách cổng mở (open ports), dịch vụ đang chạy (running services) và phiên bản hệ điều hành.
- Phân tích lỗ hổng (Vulnerability Analysis): Định lượng các điểm yếu kiến trúc, lỗi cấu hình phần mềm và các bản vá bảo mật bị bỏ sót.
- Khai thác (Exploitation): Tiến hành tấn công thực tế (ví dụ như kỹ thuật Man-in-the-Middle) nhằm minh chứng mức độ rủi ro hiện hữu đối với tổ chức.

1.3. Tổng quan về Trinh sát và Quét mạng (Footprinting & Scanning)

Để hiểu thấu đáo cách thức một cuộc tấn công mạng nội bộ diễn ra, việc nắm vững nền tảng trinh sát và quét mạng theo chuẩn đào tạo an ninh mạng quốc tế (như chuẩn CEH) là yêu cầu bắt buộc:

- Footprinting (Thu thập dấu vết): Quá trình thu thập thông tin một cách có hệ thống từ cả hai hình thức thụ động (passive) và chủ động (active) nhằm lập hồ sơ bảo mật chi tiết về tổ chức (như sơ đồ tên miền, cấu trúc phân giải DNS,

danh sách hòm thư điện tử nhân sự) mà hầu như không gây ra tiếng ồn cảnh báo trên hệ thống giám sát.

- Scanning (Quét mạng): Cầu nối mang tính quyết định chuyển dịch từ giai đoạn tình báo sang hành động khai thác thực tế. Quá trình này đòi hỏi sự tương tác trực tiếp, liên tục với hạ tầng mạng để xác định chính xác các thiết bị hoạt động, liệt kê các dịch vụ đang mở và định danh hệ điều hành thông qua phản hồi gói tin.
- Nền tảng giao thức TCP/IP: Bản chất sâu xa của các kỹ thuật quét và tấn công mạng chính là việc khai thác triệt để các quy định kỹ thuật trong các tài liệu chuẩn hóa RFC. Giao thức TCP vận hành dựa trên cơ chế bắt tay ba bước (Three-way handshake) sử dụng các cờ điều khiển (TCP Flags: SYN, ACK, FIN, RST, PSH, URG) để quản lý phiên truyền thông. Việc kẻ tấn công chủ động thao túng, hoán đổi hoặc gửi các tổ hợp cờ bất hợp lệ sẽ kích hoạt các phản ứng đặc trưng khác nhau tùy theo từng hệ điều hành đích (OS fingerprinting), từ đó giúp định danh chính xác mục tiêu.

1.4. Phân tích Lỗ hổng Bảo mật và Đánh giá Rủi ro (Vulnerability Analysis)

Phân tích lỗ hổng là quá trình định lượng có hệ thống nhằm phát hiện các khiếm khuyết trong kiến trúc thiết kế phần mềm, phần cứng và cấu hình mạng của tổ chức.

- Hệ thống chuẩn hóa quốc tế: Cộng đồng an ninh mạng toàn cầu sử dụng hệ thống từ điển CVE (Common Vulnerabilities and Exposures) để định danh chính xác từng lỗ hổng, cơ sở dữ liệu NVD (National Vulnerability Database) để quản lý thông tin chi tiết, kết hợp cùng hệ thống chấm điểm CVSS (Common Vulnerability Scoring System) nhằm đánh giá mức độ nghiêm trọng từ thấp đến nguy hiểm.
- Vòng đời quản lý lỗ hổng: Quy trình này bao gồm ba giai đoạn trọng tâm:
    - *Tiền đánh giá:* Xác định tài sản công nghệ và phạm vi kiểm tra.
    - *Đánh giá:* Thực thi quét bằng các công cụ chuyên dụng (như Nessus, Nmap, Nikto) và tiến hành lọc bỏ cảnh báo giả (false positives).

- *Hậu đánh giá:* Phân tích rủi ro kinh doanh, đưa ra phương án khắc phục và tiến hành kiểm tra lại (re-testing). Rủi ro được định lượng hóa thông qua phân tích tác động kinh doanh (BIA) dựa trên các chỉ số tổn thất kỳ vọng (SLE, ALE).

1.5. Khung Quản lý Rủi ro (Risk Management Framework) và Tiêu chuẩn An ninh Quốc tế Để xây dựng một chiến lược phòng thủ mạng toàn diện như Zero Trust, các chuyên gia an ninh mạng (theo chuẩn CEH) luôn phải tham chiếu đến các bộ tiêu chuẩn quốc tế. Nổi bật nhất là Khung quản lý rủi ro của Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ (NIST RMF - SP 800-37). Quá trình này bao gồm 6 bước cốt lõi áp dụng trực tiếp vào việc bảo vệ mạng doanh nghiệp:

- Phân loại (Categorize): Phân loại các hệ thống thông tin và thông tin được xử lý, lưu trữ, truyền tải dựa trên phân tích tác động (ví dụ: xác định máy chủ Web IIS chứa dữ liệu nhạy cảm).
- Lựa chọn (Select): Lựa chọn danh mục các biện pháp kiểm soát an ninh (Security Controls) phù hợp. Trong đồ án này, biện pháp kiểm soát được chọn là Vi phân đoạn (Micro-segmentation).
- Triển khai (Implement): Thiết lập cấu hình bảo mật trên thiết bị thực tế, cụ thể là cấu hình các luật tường lửa (Firewall Rules) trên pfSense.
- Đánh giá (Assess): Xác định xem các biện pháp kiểm soát có được triển khai chính xác và đạt hiệu quả như mong muốn hay không (Giai đoạn này tương ứng với việc dùng Kali Linux để kiểm thử ở Chương 3 và Chương 4).
- Ủy quyền (Authorize): Cấp quyền cho hệ thống hoạt động dựa trên mức độ rủi ro đã được chấp nhận.
- Giám sát (Monitor): Giám sát liên tục các luồng lưu lượng thông qua nhật ký tường lửa (Firewall Logs).

1.6. Khái niệm Bề mặt Tấn công và Ranh giới Tin cậy (Trust Boundaries) Trong kiến trúc mạng, hai khái niệm nền tảng cần làm rõ để thấy được sự ưu việt của Zero Trust là Bề mặt tấn công và Ranh giới tin cậy:

- Bề mặt tấn công (Attack Surface): Là tổng thể tất cả các điểm yếu, lỗ hổng (kể cả phần cứng, phần mềm, luồng mạng) mà kẻ tấn công có thể lợi dụng để thâm nhập hệ thống. Mạng LAN phẳng truyền thống có bề mặt tấn công cực lớn do mọi thiết bị đều "nhìn thấy" nhau.
- Ranh giới tin cậy (Trust Boundaries): Là các đường phân thủy logic phân chia mạng thành các khu vực có mức độ bảo mật khác nhau. Kẻ tấn công thường nhắm vào việc vượt qua ranh giới này. Khi vượt qua được tường lửa biên, chúng sẽ lợi dụng miền tin cậy bên trong (Trusted Zone) để thực hiện leo thang đặc quyền. Kiến trúc Zero Trust phá vỡ ranh giới này bằng cách thu hẹp miền tin cậy xuống mức từng thiết bị đơn lẻ (Micro-perimeter).

1.7. Bề mặt Tấn công Mạng Nội bộ và Sự Mong manh của Mạng Truyền thống

Kiến trúc mạng doanh nghiệp truyền thống (Traditional Network Architecture) từ lâu được thiết kế xoay quanh nguyên lý Tin cậy ngầm định (Implicit Trust) bên trong và tập trung kiểm soát chặt chẽ ranh giới biên bên ngoài (perimeter security). Tuy nhiên, mô hình này hiện lộ rõ những điểm yếu chí nguy hiểm tại Lớp 2 (Data Link Layer) và Tầng ứng dụng:

- Sự mong manh của các giao thức không mã hóa: Các giao thức mạng thế hệ cũ như Telnet (TCP 23), FTP (TCP 21), và HTTP (TCP 80) được thiết kế nguyên bản mà không tích hợp cơ chế mã hóa. Toàn bộ dữ liệu truyền tải, bao gồm cả tên tài khoản và mật khẩu định danh, đều được chuyển đi dưới dạng văn bản thô (Cleartext / Plaintext). Bất kỳ tác nhân nào có khả năng chặn bắt gói tin trên đường truyền đều có thể đọc trọn vẹn các thông tin nhạy cảm này.
- Lỗ hổng cấu trúc Lớp 2 (ARP và Switch): Mạng LAN hiện đại vận hành dựa trên các thiết bị chuyển mạch (Switch) sử dụng bảng CAM để chuyển tiếp khung dữ liệu. Tuy nhiên, giao thức phân giải địa chỉ cơ bản (ARP) hoàn toàn thiếu vắng các cơ chế xác thực danh tính, tạo ra lỗ hổng nền tảng cho phép kẻ tấn công dễ dàng thực hiện các cuộc tấn công đầu độc bảng ARP (ARP Poisoning / ARP Spoofing) để thao túng dòng chảy thông tin và thực hiện thành công kỹ thuật Man-in-the-Middle (MitM).

1.8. Hướng tiếp cận Hiện đại: Kiến trúc Bảo mật Zero Trust và Vi phân đoạn

Nhận thức rõ những bất cập chí mạng của mạng truyền thống — nơi kẻ tấn công chỉ cần vượt qua lớp tường lửa biên là có thể tự do di chuyển ngang (Lateral Movement) để chiếm đoạt toàn bộ tài nguyên — mô hình bảo mật tiên tiến Zero Trust Architecture (ZTA) đã ra đời dựa trên châm ngôn cốt lõi: *"Không bao giờ tin tưởng, luôn luôn xác minh"* (Never trust, always verify).

- Vi phân đoạn (Micro-segmentation): Đây là kỹ thuật phòng thủ nền tảng trong kiến trúc Zero Trust, thực hiện việc chia nhỏ không gian mạng thành các phân vùng độc lập, được cách ly nghiêm ngặt thông qua các chính sách tường lửa nội bộ (được cấu hình tập trung trên các tường lửa thế hệ mới như pfSense). Giải pháp này ngăn chặn triệt để khả năng giao tiếp tự do giữa các máy trạm và máy chủ, qua đó vô hiệu hóa hoàn toàn các hành vi nghe lén và tấn công MitM nội bộ.

1.9. Mô hình Kiến trúc Phòng thí nghiệm và Quy hoạch Máy ảo (VM Lab Architecture)

Để hiện thực hóa các cơ sở lý thuyết trên thành mô hình thực nghiệm trực quan, đồ án xây dựng một phòng thí nghiệm ảo hóa hoàn chỉnh trên nền tảng VMware Workstation. Môi trường bao gồm các máy ảo (Virtual Machines) được cấu hình các vai trò và thông số kỹ thuật cụ thể như sau:

1.9.1. Bảng quy hoạch hệ thống máy ảo thực nghiệm

Máy tấn công (Attacker - Kali Linux):

- *Hệ điều hành:* Kali Linux Rolling.
- *Địa chỉ IP:* 192.168.10.15 (hoặc dải Lab tương ứng).
- *Vai trò:* Đóng vai trò máy tính của kẻ tấn công trong mạng nội bộ, được tích hợp sẵn các công cụ trinh sát, đầu độc ARP (arpspoof, ettercap, bettercap) và bắt gói tin (Wireshark).

Máy nạn nhân (Victim Client - Windows 10):

- Hệ điều hành: Windows 10 Pro.
- Địa chỉ IP: 192.168.10.20.

- Vai trò: Đại diện cho máy trạm của người dùng trong doanh nghiệp, thực hiện các thao tác truy cập ứng dụng web nội bộ.

Máy chủ mục tiêu (Target Server - Windows Server):

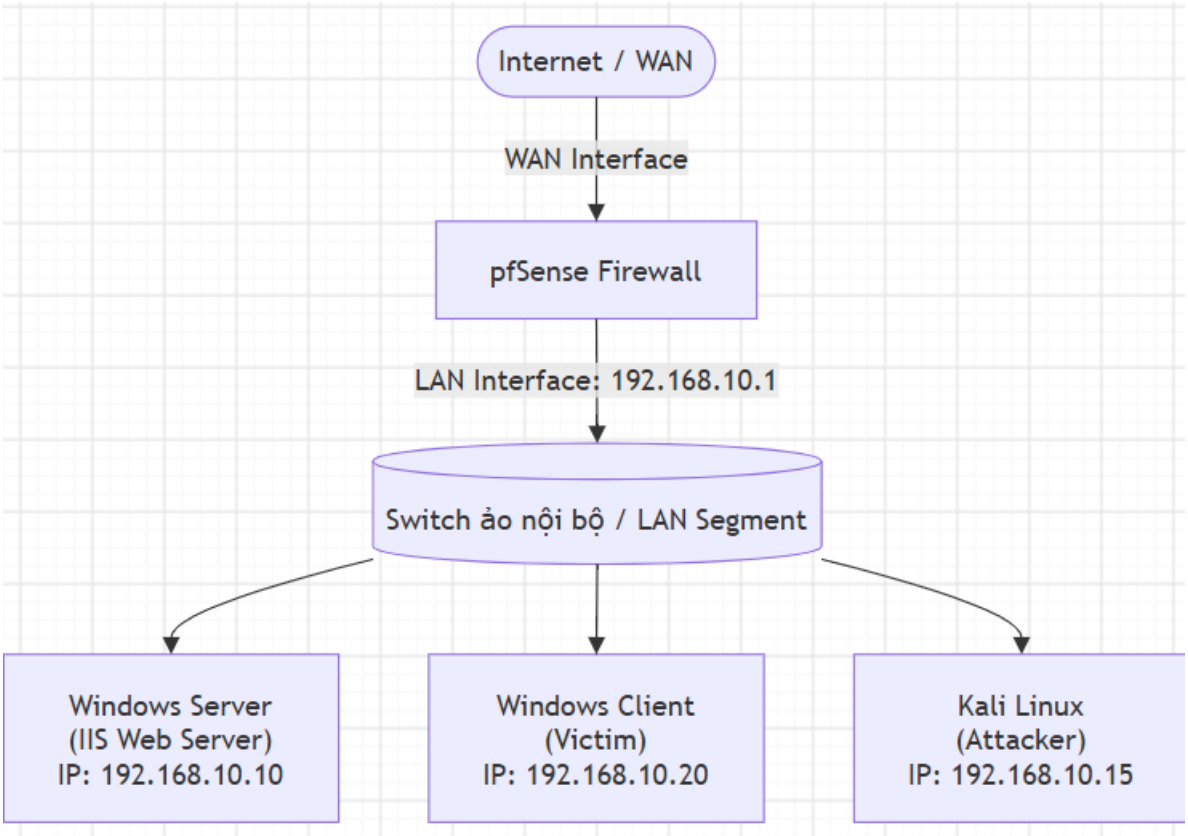
- Hệ điều hành: Windows Server (Cài đặt dịch vụ IIS).
- Địa chỉ IP: 192.168.10.10.
- Vai trò: Lưu trữ và vận hành ứng dụng web mồi chạy trên nền tảng HTTP không mã hóa (cổng 80) với biểu mẫu đăng nhập (/submit).

Cổng định tuyến và Tường lửa (Gateway & Firewall - pfSense):

- Hệ điều hành: pfSense Firewall (FreeBSD).
- Địa chỉ IP: 192.168.1.1 (WAN) / 192.168.10.1 (LAN).
- Vai trò: Đảm nhiệm vai trò tường lửa biên, định tuyến gói tin và thực hiện chính sách Vi phân đoạn (Micro-segmentation) trong giai đoạn chuyển đổi sang kiến trúc Zero Trust.

1.9.2. Sơ đồ kết nối mạng tổng quan của phòng thí nghiệm

Dưới đây là sơ đồ cấu trúc kết nối giữa các máy ảo trong mô hình phòng thí nghiệm thực tế của đồ án:



Sơ đồ kết nối mạng tổng quan

1.10. Kết luận chương 1

Chương 1 đã hệ thống hóa toàn diện các cơ sở lý thuyết nền tảng về an toàn thông tin, phương pháp luận trinh sát, quét mạng, phân tích lỗ hổng, đồng thời giới thiệu chi tiết mô hình kiến trúc phòng thí nghiệm ảo hóa cùng sơ đồ kết nối các máy ảo. Những nội dung này kết hợp với việc chỉ ra điểm yếu chí mạng của mạng nội bộ truyền thống tạo ra khung lý luận vững chắc làm tiền đề để triển khai thực nghiệm tấn công MitM tại Chương 2 và Chương 3, cũng như đề xuất giải pháp chuyển đổi chiến lược sang kiến trúc Zero Trust tại các chương tiếp theo của đồ án.

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT VỀ TẤN CÔNG MAN-IN-THE-MIDDLE, SNIFFING VÀ LỖ HỔNG MẠNG TRUYỀN THỐNG

2.1. Kiến trúc Mạng Truyền thống (Traditional Network Architecture) và Mô hình Tin cậy Ngầm định

Trong suốt nhiều thập kỷ qua, mô hình thiết kế mạng doanh nghiệp và phòng thí nghiệm phần lớn dựa trên kiến trúc mạng truyền thống (Traditional Network Architecture), nơi ranh giới ngoại vi của hệ thống được bảo vệ kiên cố bởi các thiết bị tường lửa biên (Perimeter Security). Triết lý thiết kế cốt lõi của mô hình này được xây dựng dựa trên nguyên lý Tin cậy ngầm định (Implicit Trust), thường được ví von theo mô hình phòng thủ cổ điển "Lâu đài và Hào nước" (Castle-and-Moat).

Theo mô hình này:

- Bên ngoài biên mạng (External / Untrusted Zone): Được nhìn nhận là vùng hoàn toàn không an toàn, tập trung chứa đựng mọi mối đe dọa tiềm tàng xuất phát từ không gian Internet công cộng rộng lớn.
- Bên trong mạng nội bộ (Internal LAN / Trusted Zone): Được mặc định cấu hình là vùng hoàn toàn an toàn. Mọi thiết bị phần cứng, máy trạm người dùng (Client), máy chủ dữ liệu (Server) và thiết bị định tuyến khi đã kết nối thành công vào mạng nội bộ thông qua switch vật lý hoặc mạng thông qua các switch ảo trong Lab đều được cấp một mức độ tín nhiệm cao độ. Hệ thống cho phép chúng giao tiếp hoàn toàn tự do với nhau qua hầu hết các cổng dịch vụ mà

không đòi hỏi phải trải qua các bước xác thực danh tính ngặt nghèo hay kiểm tra phân quyền chi tiết ở từng phân đoạn nhỏ.

Tuy nhiên, sự bùng nổ của các hình thức tấn công nội gián và kỹ thuật di chuyển ngang (Lateral Movement) trong thực tế đã minh chứng rằng mô hình tin cậy ngầm định ẩn chứa những rủi ro tử huyệt. Một khi kẻ tấn công tìm cách vượt qua được lớp phòng thủ biên (hoặc đã có sẵn một thiết bị thâm nhập cắm trực tiếp trong mạng LAN như máy tính tấn công Kali Linux được tích hợp sẵn trong môi trường Lab), toàn bộ cấu trúc phòng thủ bên trong sẽ sụp đổ hoàn toàn do sự thiếu vắng các lớp kiểm soát vi phân đoạn.

2.2. Phân tích Kỹ thuật Tấn công Man-in-the-Middle (MitM)

Man-in-the-Middle (MitM) là một hình thức tấn công mạng mang tính chiến lược và có chiều sâu, trong đó kẻ tấn công âm thầm chèn vị trí của mình vào giữa luồng giao tiếp trực tiếp giữa hai thực thể độc lập trong mạng (ví dụ: giữa máy trạm nạn nhân Client 192.168.10.20 và máy chủ nội bộ Windows Server 192.168.10.10) mà cả hai phía đầu cuối đều hoàn toàn không hề hay biết về sự tồn tại của kẻ trung gian.

2.2.1. Bản chất và Mục tiêu của MitM

Mục tiêu cốt lõi của tấn công MitM không nằm ở việc làm tê liệt hệ thống (như các hình thức tấn công Từ chối dịch vụ - DoS/DDoS), mà tập trung vào việc thao túng, kiểm soát và khai thác dòng chảy thông tin. Khi đã đứng vững ở vị trí trung gian, kẻ tấn công có thể đạt được ba mục đích trọng tâm:

- Nghe lén và Thu thập dữ liệu (Eavesdropping): Ghi lại toàn bộ lưu lượng dữ liệu trao đổi qua lại, bao gồm các thông tin xác thực định danh, tài liệu nội bộ nhạy cảm và các lệnh quản trị hệ thống.
- Chỉnh sửa dữ liệu trực tuyến (Tampering): Thay đổi linh hoạt nội dung các gói tin trên đường truyền (ví dụ: tiêm nhiễm mã độc vào các gói cập nhật phần mềm tải về qua HTTP) trước khi chuyển tiếp chúng đến nạn nhân.
- Mạo danh phiên làm việc (Session Hijacking): Đóng vai trò đồng thời là máy chủ đối với phía client và là client đối với phía máy chủ thực sự, qua mặt toàn bộ các cơ chế kiểm soát phiên làm việc.

2.2.2. Yêu cầu kỹ thuật để thực thi MitM trong mạng LAN

Trong một cấu trúc mạng chuyển mạch hiện đại (Switch-based LAN hoặc môi trường Switch ảo của VMware), các thiết bị giao tiếp thông qua thiết bị chuyển mạch dựa trên địa chỉ MAC và bảng CAM, khiến dữ liệu của máy này thông thường không đi qua máy của máy khác. Do đó, để hiện thực hóa kỹ thuật MitM, kẻ tấn công bắt buộc phải tiến hành thủ thuật đầu độc bộ đệm ARP nhằm ép buộc toàn bộ luồng lưu lượng truyền thông phải đi qua máy của mình (trong mô hình lab của đề tài là máy Kali Linux 192.168.10.15).

2.3. Cơ chế Hoạt động của Giao thức ARP và Kỹ thuật ARP Spoofing / Poisoning

Giao thức Phân giải Địa chỉ (Address Resolution Protocol - ARP) là một giao thức nền tảng hoạt động ở ranh giới Lớp 2 (Data Link Layer) và Lớp 3 (Network Layer) trong mô hình OSI, chịu trách nhiệm thực hiện việc ánh xạ địa chỉ IP logic ở Lớp 3 sang địa chỉ MAC phần cứng vật lý ở Lớp 2 trong phạm vi mạng cục bộ.

2.3.1. Lỗ hổng cấu trúc nguyên bản của ARP

Giao thức ARP được nghiên cứu, thiết kế và tiêu chuẩn hóa từ những năm đầu hình thành mạng Internet, thời kỳ mà yếu tố bảo mật an ninh chưa được đặt lên hàng đầu. Chính vì vậy, ARP mang trong mình một điểm yếu cấu trúc chí mạng: Hoàn toàn không có cơ chế xác thực danh tính (Stateless & Unauthenticated).

- Bất kỳ thiết bị nào kết nối trong mạng cũng có thể phát tán một gói tin phản hồi ARP (ARP Reply) mà không cần thiết phải nhận được bất kỳ yêu cầu thăm dò nào trước đó (hành vi này gọi là *Gratuitous ARP*).
- Hệ điều hành của các thiết bị mạng phổ biến (Windows, Linux) được lập trình theo cơ chế tự động cập nhật bảng bộ đệm cá nhân (ARP Cache) ngay lập tức khi nhận được bất kỳ gói tin ARP Reply nào chứa thông tin mới hơn, nhằm duy trì tính linh hoạt và khả năng cập nhật tự động của mạng.

2.3.2. Phân tích Chuyên sâu Cơ chế Bảng CAM trên Thiết bị Chuyển mạch(Switch)

Để hiểu rõ tại sao tấn công MitM có thể thực hiện trên mạng LAN, cần đi sâu vào kiến trúc phần cứng của thiết bị chuyển mạch (Switch) hoặc các Switch ảo (VMnet) trong

môi trường VMware. Switch hoạt động dựa trên một cấu trúc dữ liệu đặc biệt gọi là Bảng CAM (Content Addressable Memory).

- Cơ chế học địa chỉ (MAC Learning): Khi một khung dữ liệu (Frame) đi vào cổng của Switch, Switch sẽ đọc địa chỉ MAC nguồn và ghi nhận: Địa chỉ MAC này đang được gắn với cổng vật lý (hoặc cổng logic) nào.
- Chuyển tiếp gói tin (Forwarding): Khi có gói tin cần gửi đi, Switch tra cứu bảng CAM để tìm cổng tương ứng với địa chỉ MAC đích và chỉ đẩy gói tin ra đúng cổng đó, tạo sự riêng tư cho luồng dữ liệu.
- Lỗ hổng lợi dụng: Các công cụ tấn công như Arpspoof không trực tiếp tấn công Switch, mà chúng đánh lừa các thiết bị đầu cuối (End-devices) để các thiết bị này tự nguyện thay đổi địa chỉ MAC đích trong khung dữ liệu thành MAC của kẻ tấn công. Khi đó, Switch vẫn hoạt động "đúng chức năng" của nó là đẩy gói tin đến vị trí của kẻ tấn công, vô tình trở thành đồng phạm trong quá trình MitM.

2.3.3. Quá trình xử lý ARP tại lõi Hệ điều hành (OS Kernel)

Điểm yếu chí mạng thứ hai nằm ở lõi (Kernel) của các hệ điều hành phổ biến (như Windows, Linux). Theo chuẩn RFC 826 định nghĩa về ARP, các hệ điều hành được thiết kế với tiêu chí "Tối ưu hóa hiệu năng" thay vì "Bảo mật":

- Cập nhật phi trạng thái (Stateless Update): Khi Kernel nhận được một gói tin ARP Reply, nó không hề kiểm tra xem trước đó nó có gửi đi gói tin ARP Request nào để hỏi thông tin này hay không.
- Cơ chế ghi đè tự động (Automatic Overwrite): Ngay khi nhận được gói ARP Reply giả mạo từ Kali Linux (dù không yêu cầu), Kernel của Windows 10 (Client) và Windows Server ngay lập tức xóa bỏ bản ghi cũ và ghi đè thông tin MAC giả mạo vào bộ đệm (ARP Cache). Chính sự "ngây thơ" này ở mức Kernel đã tạo điều kiện tiên quyết cho các công cụ như Ettercap, Bettercap thao túng hoàn toàn luồng mạng.

2.3.4. Quy trình thực thi ARP Spoofing qua công cụ arpspoof

Trong mô hình thử nghiệm thực tế của đề tài, các công cụ chuyên dụng như arpspoof (hoặc ettercap, bettercap) trên nền tảng Kali Linux được vận hành để khai thác triệt để lỗ hổng này:

Đầu độc phía Client (Victim): Máy tấn công Kali Linux liên tục phát tán các gói tin ARP Reply giả mạo tới máy Client (192.168.10.20), tuyên truyền rằng địa chỉ IP của Windows Server (192.168.10.10) hiện đang ứng với địa chỉ MAC của máy Kali.

Đầu độc phía Server: Kali Linux đồng thời gửi các gói tin ARP Reply giả mạo tới Windows Server (192.168.10.10), khẳng định rằng địa chỉ IP của Client (192.168.10.20) tương ứng với địa chỉ MAC của máy Kali.

Kết quả bảng ARP bị bẻ cong: Bảng ARP Cache của cả Client và Windows Server đều bị ghi đè thông tin sai lệch trầm trọng. Toàn bộ các khung dữ liệu Ethernet (Ethernet Frames) truyền tải giữa hai máy này không còn chuyển tiếp thẳng tới nhau nữa, mà bị bẻ lái hướng thẳng đến card mạng eth0 của máy Kali Linux.

Vai trò cốt lõi của IP Forwarding trên Kali Linux:

- Khi Kali nhận được các gói tin bị bẻ lái nhưng tính năng chuyển tiếp gói tin (net.ipv4.ip_forward = 0) chưa được kích hoạt trên hệ điều hành, máy Kali sẽ tự động giữ hoặc hủy bỏ gói tin, dẫn đến việc máy Client bị mất kết nối mạng đột ngột (ERR_CONNECTION_TIMED_OUT).
- Khi lệnh bật chuyển tiếp được thực thi (net.ipv4.ip_forward = 1), máy Kali đóng vai trò hoàn hảo như một bộ định tuyến trung gian (Router), âm thầm tiếp nhận, sao chép nội dung gói tin và đẩy tiếp chúng đến đúng địa chỉ đích thực sự. Nhờ đó, máy Client vẫn truy cập được dịch vụ web bình thường mà hoàn toàn không nghi ngờ gì, trong khi kẻ tấn công đã nắm quyền kiểm soát toàn bộ luồng dữ liệu ở giữa.

2.4. Kỹ thuật Đánh hơi Mạng (Network Sniffing) và Chế độ Promiscuous Mode

Sau khi đã thiết lập thành công vị trí trung gian thông qua tấn công MitM, bước tiếp theo nhằm trích xuất thông tin nhạy cảm là ứng dụng kỹ thuật đánh hơi mạng (Network Sniffing).

2.4.1. Nguyên lý hoạt động của Card mạng và Chế độ Hỗn tạp

- Non-Promiscuous Mode (Chế độ chuẩn): Theo mặc định thông thường, card mạng (NIC) của một thiết bị chỉ chấp nhận tiếp nhận các khung dữ liệu có địa chỉ MAC đích trùng khớp tuyệt đối với địa chỉ MAC của chính nó. Mọi gói tin khác bay qua đường truyền cáp mạng sẽ bị phần cứng âm thầm loại bỏ.
- Promiscuous Mode (Chế độ hỗn tạp): Khi thực hiện sniffing bằng các công cụ phân tích như Wireshark trên máy Kali Linux (192.168.10.15), card mạng (eth0) được chuyển đổi sang trạng thái Promiscuous. Ở chế độ này, mọi bộ lọc phần cứng bị vô hiệu hóa hoàn toàn, cho phép card mạng tiếp nhận, ghi lại và đẩy toàn bộ các dòng khung dữ liệu di chuyển qua phân đoạn mạng lên tầng xử lý phần mềm.

2.4.2. Vai trò của bộ lọc hiển thị (Display Filters) trong Wireshark

Do lưu lượng mạng thực tế chứa rất nhiều gói tin hệ thống chạy ngầm (như phân giải tên miền DNS, lưu lượng mã hóa TLS/SSL, giao thức chia sẻ tệp SMB, các gói ARP định kỳ), việc phân tích thủ công bằng mắt thường là bất khả thi. Các kỹ sư bảo mật phải sử dụng hệ thống bộ lọc hiển thị của Wireshark (như bộ lọc http) để bóc tách và loại bỏ các gói tin nhiễu, tập trung hoàn toàn vào các luồng giao thức tầng ứng dụng cần phân tích.

2.5. Phân tích Sự mong manh của các Giao thức Tầng Ứng dụng trong Mạng Cục bộ

Thành công của một chiến dịch khai thác thông tin xác thực phụ thuộc hoàn toàn vào thiết kế của các giao thức tầng ứng dụng (Application Layer).

2.5.1. Giao thức HTTP (Hypertext Transfer Protocol - Cổng 80)

HTTP là giao thức truyền tải siêu văn bản hoạt động ở tầng ứng dụng, được thiết kế nguyên bản dựa trên nền tảng không mã hóa (Cleartext / Plaintext).

- Khi người dùng tương tác với một trang web chạy HTTP (ví dụ truy cập ứng dụng mồi trên Windows Server 192.168.10.10 từ máy Client 192.168.10.20), mọi dữ liệu từ trình duyệt Client gửi đi (bao gồm phương thức HTTP GET, HTTP POST, các tham số form đăng nhập, cookie phiên làm việc) đều được đóng gói dưới dạng văn bản rõ nghĩa.

- Thông qua công cụ Wireshark trên trạm Kali Linux, khi mở chi tiết gói tin có trường chứa nội dung HTML Form URL Encoded: application/x-www-form-urlencoded, kẻ tấn công có thể nhìn thấy trọn vẹn các trường thông tin định danh như username và password hiện lên rõ mồn một dưới dạng chuỗi ký tự tường minh mà không cần tốn bất kỳ tài nguyên tính toán nào để giải mã.

2.5.2. Giao thức FTP (File Transfer Protocol - Cổng 21/20)

Tương tự HTTP, FTP là giao thức truyền tải tệp tin truyền thống sử dụng hai kênh kết nối riêng biệt: Cổng 21 dành cho lệnh điều khiển (Control Connection) và Cổng 20 dành cho dữ liệu truyền tải (Data Connection).

- Toàn bộ các câu lệnh xác thực quan trọng như lệnh USER và lệnh PASS trong phiên làm việc FTP đều được truyền đi dưới dạng văn bản thuần túy qua cổng 21, dễ dàng bị bắt giữ bằng bộ lọc ftp trên Wireshark.

2.6. Tổng quan về Dịch vụ Web IIS (Internet Information Services) trong Môi trường Lab

Để mô phỏng một môi trường thực tế phục vụ cho việc kiểm chứng đồ án, một máy chủ Windows Server (192.168.10.10) đã được cấu hình dịch vụ web IIS (Internet Information Services):

- IIS Server Role: Là máy chủ web mạnh mẽ do tập đoàn Microsoft phát triển, tích hợp sẵn trên hệ điều hành Windows Server, hỗ trợ lưu trữ các trang web tĩnh (HTML, CSS, JavaScript) và ứng dụng động (ASP.NET).
- Trang web mồi (Index.html Form): Một biểu mẫu đăng nhập cơ bản được thiết lập trên IIS (http://192.168.10.10), sử dụng phương thức POST để truyền tải dữ liệu đến đường dẫn xử lý (/submit).
- Việc sử dụng IIS chạy trên nền tảng giao thức HTTP không bảo mật chính là thành phần cốt lõi để tái hiện lỗ hổng hệ thống trong Lab, tạo ra minh chứng kỹ thuật rõ nét về mức độ rủi ro khi doanh nghiệp duy trì các ứng dụng nội bộ không mã hóa.

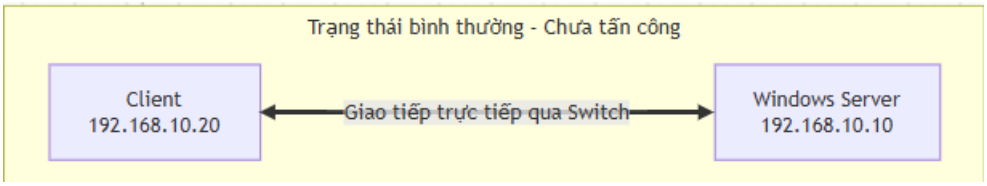
2.7. Đánh giá Rủi ro Di chuyển Ngang (Lateral Movement) trong Mạng LAN Phẳng

Từ những cơ sở lý thuyết vững chắc và kết quả thực nghiệm tấn công, có thể rút ra đánh giá toàn diện về bề mặt rủi ro của mô hình mạng truyền thống:

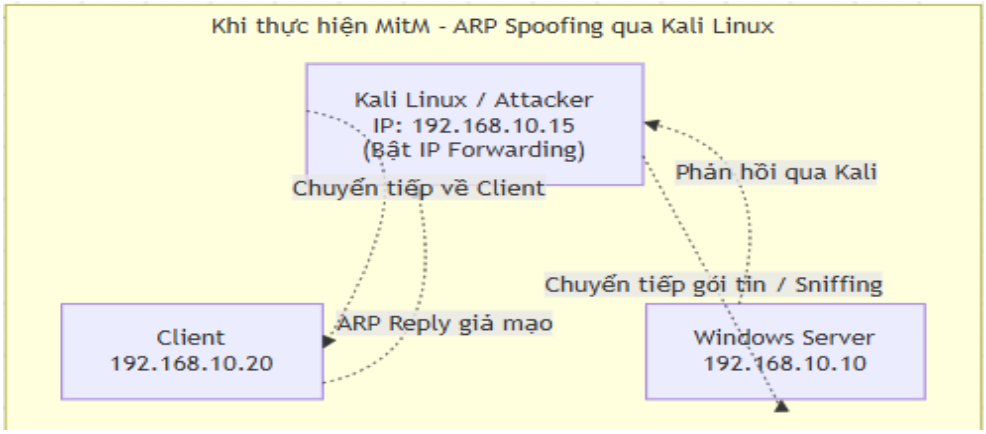
- Thiếu phân vùng (Lack of Segmentation): Các thiết bị trong cùng một dải subnet có thể tự do giao tiếp trực tiếp với nhau qua mọi cổng dịch vụ mà không gặp bất kỳ rào cản nào.
- Di chuyển ngang (Lateral Movement): Khi kẻ tấn công chiếm được một điểm tựa duy nhất (như máy Kali Linux trong mạng nội bộ), chúng dễ dàng thực hiện quét mạng, tấn công ARP Spoofing, nghe lén thông tin xác thực của quản trị viên và leo thang đặc quyền để kiểm soát toàn bộ các máy chủ cốt lõi khác trong hệ thống doanh nghiệp.

2.8. Sơ đồ Tương tác và Luồng Giao tiếp trong Mô hình Lab Truyền thống

Dưới đây là sơ đồ mô tả luồng giao tiếp bị bẻ lái khi kẻ tấn công thực hiện kỹ thuật Man-in-the-Middle giữa máy Client và máy chủ Windows Server IIS trong môi trường phòng thí nghiệm:



Sơ đồ: khi chưa tấn công



Sơ đồ: khi thực hiện tấn công thử

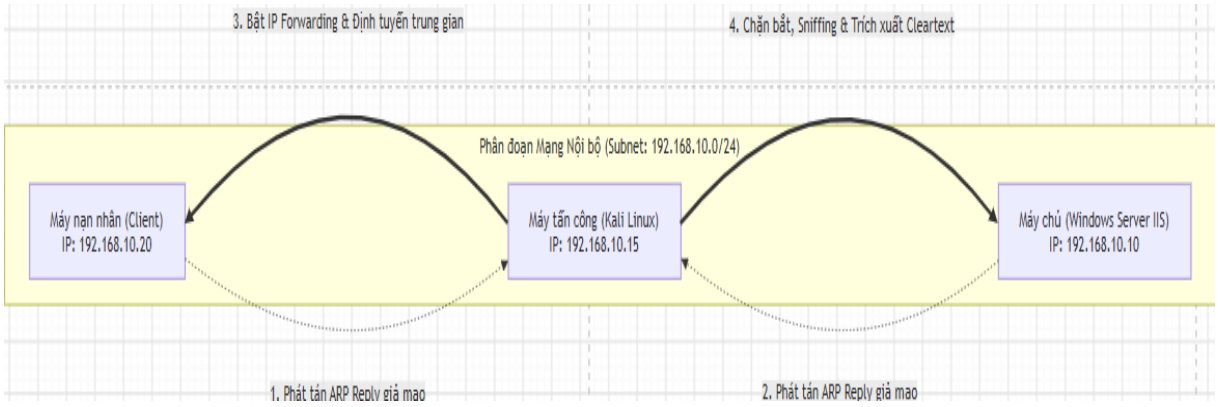
2.9. Kết luận Chương 2

Chương 2 đã cung cấp bức tranh toàn cảnh về cơ sở lý thuyết kỹ thuật tấn công Man-in-the-Middle, cơ chế đầu độc ARP, phương pháp đánh hơi gói tin qua Wireshark, cấu hình dịch vụ IIS Server trên mô hình Lab thực tế và lỗ hổng chí mạng của các giao thức văn bản thuần túy. Đây là nền tảng lý luận vững chắc làm tiền đề cho việc triển khai các bài test thực tế tại Chương 3 và đề xuất giải pháp kiến trúc bảo mật tiên tiến Zero Trust (Micro-segmentation trên pfSense) ở các chương tiếp theo của đồ án.

CHƯƠNG 3: THỰC NGHIỆM TẤN CÔNG MẠNG TRUYỀN THỐNG (MAN-IN-THE-MIDDLE & SNIFFING) VÀ ĐÁNH GIÁ RỦI RO

3.1. Sơ đồ Tổng quan Quy trình Tấn công Man-in-the-Middle trong Phòng thí nghiệm

Để trực quan hóa toàn bộ luồng thực thi tấn công từ máy kẻ tấn công (Kali Linux) nhắm vào cặp mục tiêu (Client và Windows Server IIS) trong mạng LAN phẳng, sơ đồ tổng quan luồng tương tác được thể hiện như sau:



Sơ đồ tổng quan quá trình tấn công

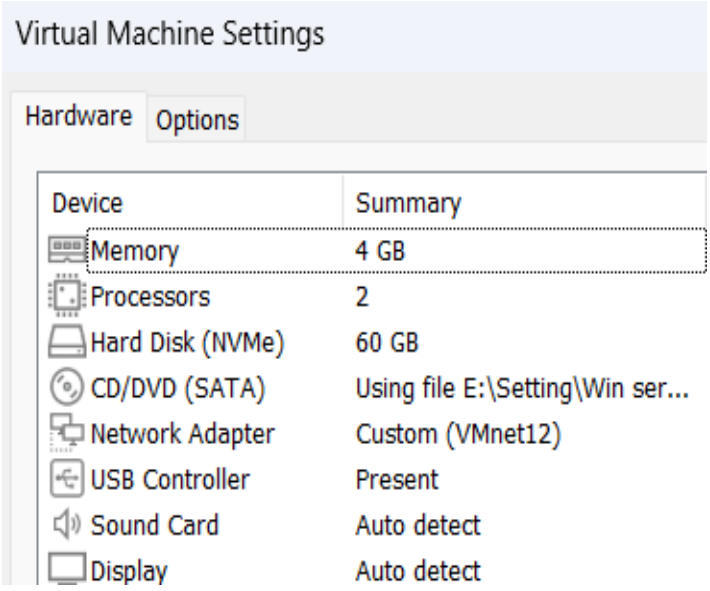
3.2. Mục tiêu và Phương pháp luận Thực nghiệm

Chương này tập trung triển khai các bài kiểm thử xâm nhập thực tế nhằm đánh giá mức độ an toàn của kiến trúc mạng nội bộ truyền thống. Mục tiêu chính là minh họa cách thức kẻ tấn công lợi dụng các điểm yếu cơ bản ở Lớp 2 (Data Link Layer) và sự thiếu vắng mã hóa ở Tầng ứng dụng để thực hiện thành công kỹ thuật Man-in-the-Middle (MitM) và Network Sniffing, từ đó thu thập trái phép thông tin định danh của quản trị viên.

Mô hình phòng thí nghiệm được thiết lập gồm các thành phần:

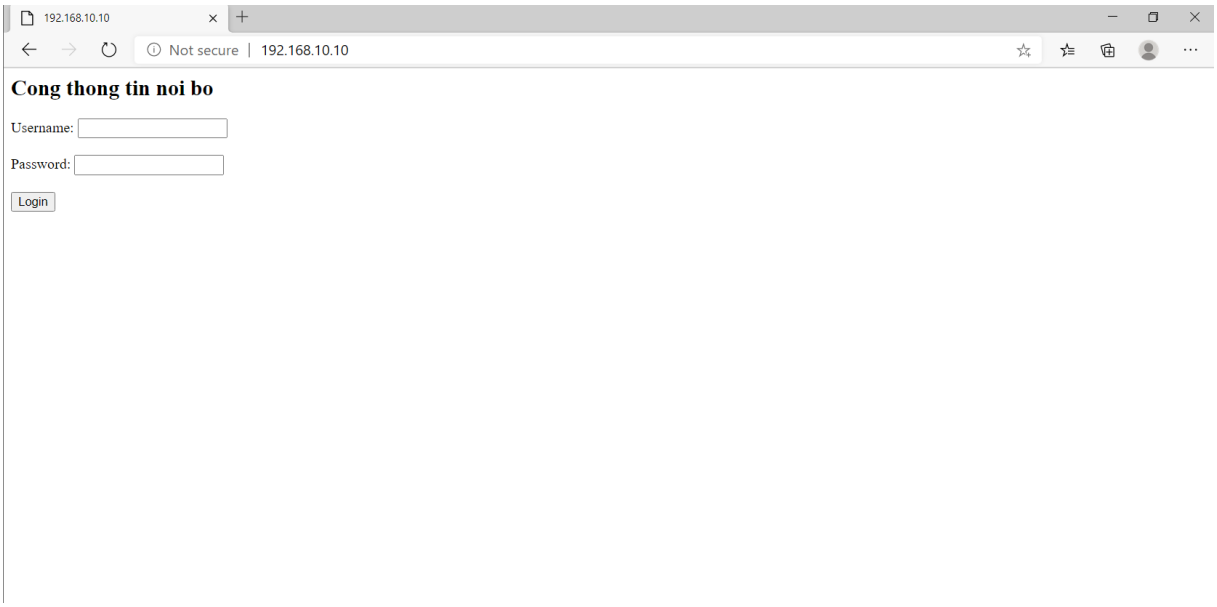
- Máy tấn công (Attacker): Kali Linux (192.168.10.15), đóng vai trò thực thi các công cụ kiểm thử mạng
- Máy nạn nhân (Victim Client): Windows 10 (192.168.10.20), nơi người dùng thực hiện các thao tác duyệt web thông thường.
- Máy chủ mục tiêu (Target Server): Windows Server (192.168.10.10) cấu hình dịch vụ web IIS, vận hành ứng dụng trên giao thức HTTP không mã hóa (cổng 80).
- Máy pfsense(firewall): filewall này đóng vai trò là một tường lửa nhưng chưa có can thiệp gì vào đợt tấn công lần này.

Đợt tấn công lần này ta sẽ thực hiện trên mạng nội bộ thông qua server+victim+kali linux.



Cấu hình card mạng VMnet12 cho cả máy victim, kali và server

Nhằm tránh quét các web bên ngoài ta thông qua server tạo một web ảo không đáng tín HTTP



Hình ảnh web của server tạo ra

3.3. Thực nghiệm 1: Tấn công Man-in-the-Middle và Sniffing sử dụng công cụ arpspoof

3.3.1. Cơ sở lý thuyết và Quy trình thực thi

Công cụ arpspoof (thuộc bộ gói dsniff trên Kali Linux) là một tiện ích kinh điển dùng để ép buộc các thiết bị trong mạng LAN chấp nhận các gói tin phản hồi ARP giả mạo. Để đảm bảo máy nạn nhân không bị mất kết nối Internet hoặc mạng nội bộ trong suốt quá trình tấn công, kỹ thuật viên bắt buộc phải kích hoạt tính năng chuyển tiếp gói tin trên hệ điều hành Linux:

Bash

sudo sysctl -w net.ipv4.ip_forward=1

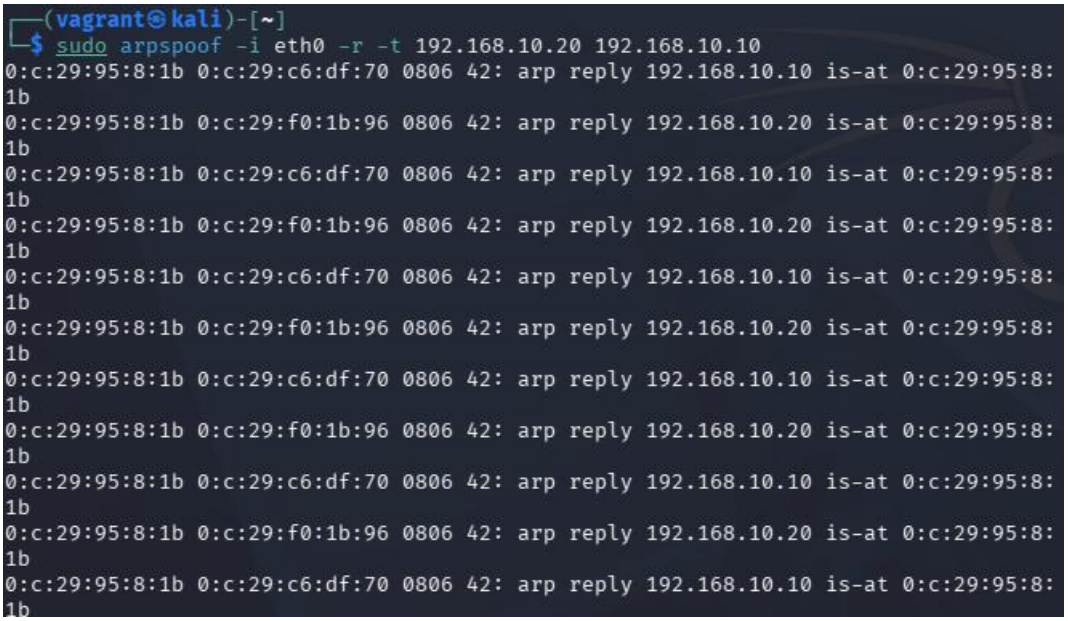
3.3.2. Trình tự phân tích và Minh chứng Hình ảnh Thực thực nghiệm

Quá trình thực nghiệm với arpspoof được ghi nhận qua 3 bước hình ảnh tuần tự:

Bước 1: Lệnh chạy tấn công arpspoof

Phân tích kỹ thuật: Cửa sổ Terminal đang chạy công cụ arpspoof, liên tục phát tán các gói tin arp reply giả mạo vào mạng nội bộ. Các gói tin này ép máy Client (192.168.10.20)

và máy Windows Server (192.168.10.10) tin rằng địa chỉ MAC của đối phương chính là địa chỉ MAC của máy Kali Linux. Hậu quả là toàn bộ lưu lượng giao tiếp không còn đi trực tiếp qua Switch, mà bị chuyển hướng chạy xuyên qua card mạng eth0 của máy Kali Linux.



Hình ảnh chạy lệnh tấn công arpspoof trên terminal của kali linux

Bước 2: Đăng nhập web HTTP bất kỳ cần nhập user và password (Trích xuất dữ liệu nhạy cảm)

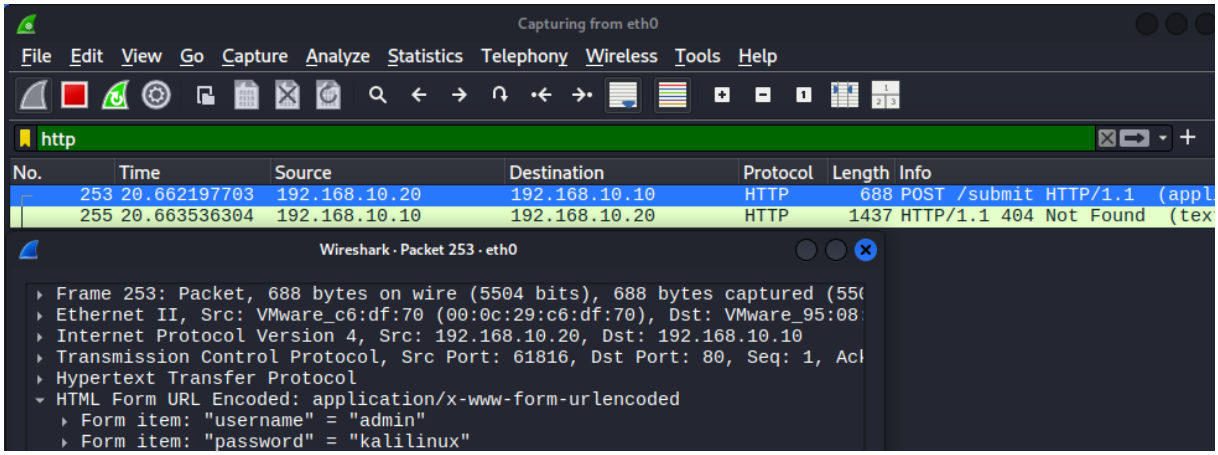
Phân tích kỹ thuật*:* Tại gói tin số 707 mang phương thức POST /submit HTTP/1.1 gửi từ Client đến Server, Wireshark đã bóc tách lớp ứng dụng (Application Layer) và phơi bày hoàn toàn thông tin trong phần HTML Form URL Encoded. Các thông tin đăng nhập bị lộ rõ dưới dạng văn bản thô (*cleartext*) bao gồm:



Hình ảnh user và password cần đăng nhập bất kỳ trên web

Bước 3: Wireshark bắt gói tin

Phân tích kỹ thuật: Nhờ việc đứng giữa luồng dữ liệu (MitM) và bật chế độ chuyển tiếp IP (ip_forward), công cụ Wireshark trên Kali dễ dàng bắt được toàn bộ các gói tin giao tiếp. Bằng cách áp dụng bộ lọc http, máy tấn công đã cô lập được các luồng dữ liệu web.



Hình ảnh wireshark đã bắt được thông tin của web HTTP

3.3.3. Đánh giá rủi ro từ thực nghiệm arpspoof

Từ kết quả thực nghiệm trên, chúng ta rút ra những đánh giá rủi ro nghiêm trọng đối với kiến trúc mạng nội bộ truyền thống: Lỗ hổng tin cậy ngầm định (Implicit Trust) khiến giao thức ARP ở Lớp 2 không có cơ chế xác thực danh tính. Tường lửa biên truyền thống hoàn toàn bị "mù" trước luồng dữ liệu nội bộ này. Việc sử dụng HTTP

kết hợp MitM khiến dữ liệu định danh (admin / kalilinux) bị phơi bày trực tiếp, dẫn đến mất kiểm soát hệ thống.

3.4. Thực nghiệm 2: Tấn công Man-in-the-Middle và Sniffing sử dụng công cụ Ettercap

3.4.1. Cơ sở lý thuyết và Quy trình thực thi

Ettercap là một khung công cụ toàn diện hỗ trợ phân tích và tấn công chuyển mạch mạng, cung cấp khả năng tự động hóa cao trong việc thực hiện đầu độc ARP hai chiều và tích hợp sẵn bộ bắt gói tin tầng ứng dụng. Lệnh thực thi tiêu chuẩn trên Kali Linux:

Bash

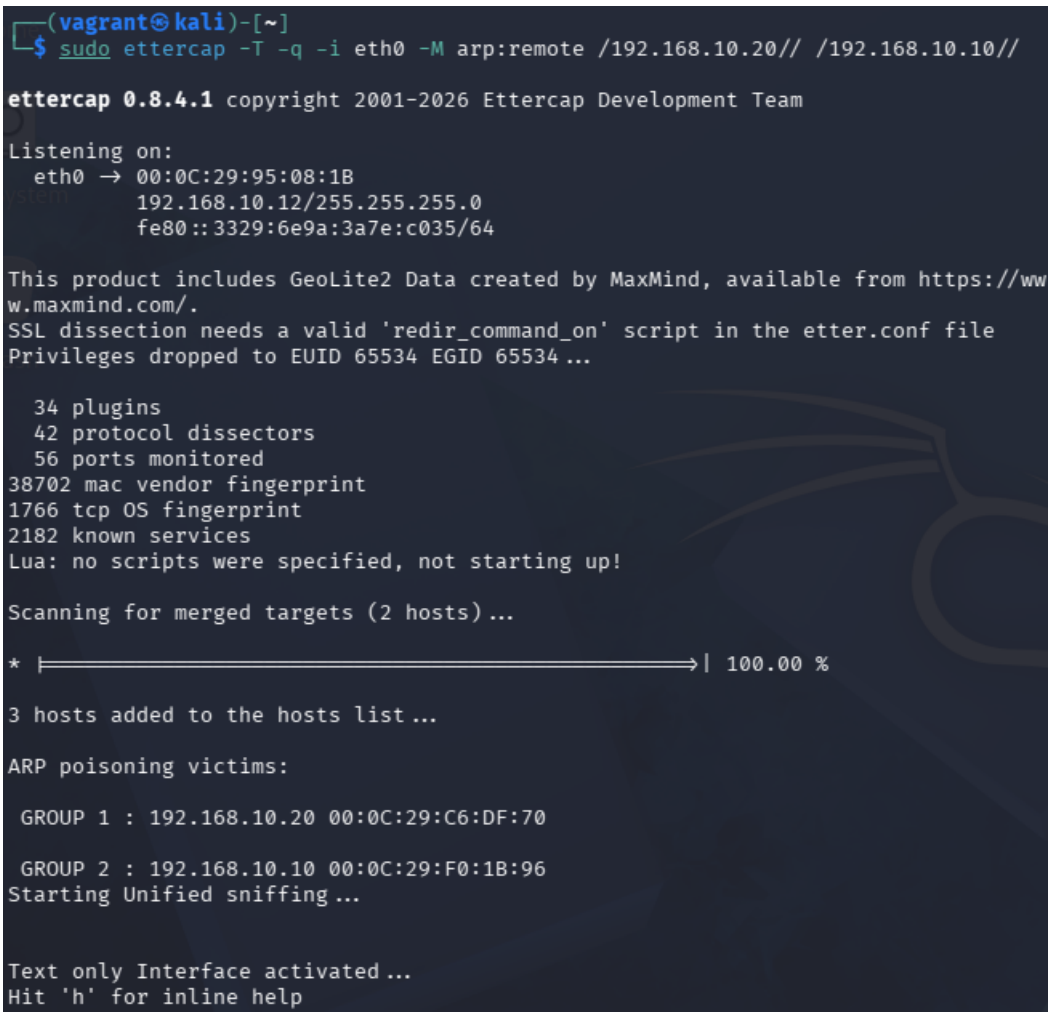
```
sudo ettercap -T -q -i eth0 -M arp:remote /192.168.10.20// /192.168.10.10//
```

3.4.2. Trình tự phân tích và Minh chứng Hình ảnh Thực nghiệm

Quá trình thực nghiệm với Ettercap được minh chứng qua 3 bước hình ảnh tuần tự:

Bước 1: Chụp màn hình lệnh chạy tấn công (Ettercap)

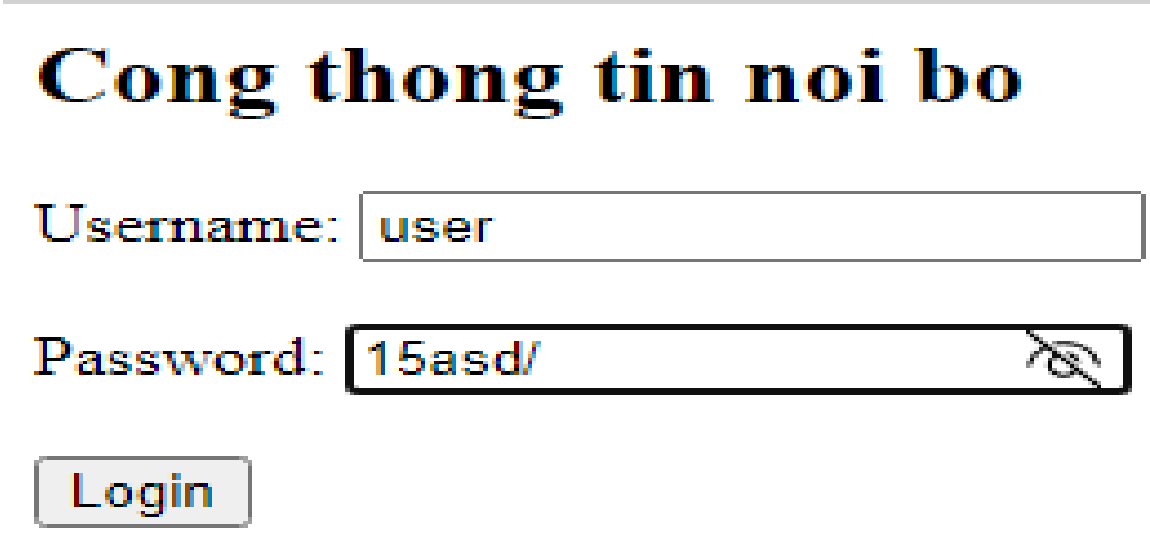
Phân tích kỹ thuật*:* Cửa sổ Terminal khởi chạy Ettercap ở chế độ dòng lệnh văn bản (-T), thực hiện thành công quá trình đầu độc bảng ARP (ARP Poisoning) giữa máy Client (192.168.10.20) và máy chủ Windows Server IIS (192.168.10.10). Toàn bộ gói tin trao đổi giữa hai máy này đã bị ép buộc chuyển hướng đi qua máy tấn công (Kali Linux).



Hình ảnh chạy lệnh tấn công Ettercap trên terminal của kali linux

Bước 2: Đăng nhập web HTTP bất kỳ cần nhập user và password (Trích xuất dữ liệu nhạy cảm)

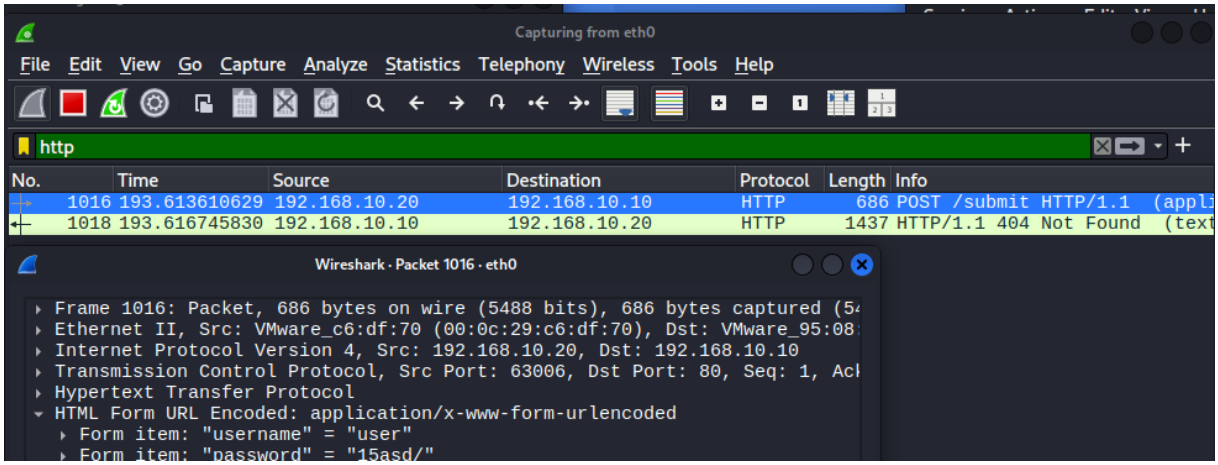
Phân tích kỹ thuật*:* Gói tin phản hồi số 1094 từ Windows Server trả về mã trạng thái 404 Not Found. Ý nghĩa kỹ thuật: Dù đường dẫn /submit chưa tồn tại trên IIS, điều này không làm ảnh hưởng đến việc kẻ tấn công đã thu giữ thành công gói tin yêu cầu chứa thông tin nhạy cảm được gửi đi ở bước trước đó.



Hình ảnh user và password của web HTTP

Bước 3: Wireshark bắt gói tin

Phân tích kỹ thuật: Giao diện Wireshark ghi nhận chi tiết các gói tin HTTP được luân chuyển qua trạm trung gian. Cụ thể, gói tin số 1092 ghi nhận phương thức POST /submit HTTP/1.1 từ Client gửi tới Server tại thời điểm 36.348820678. Phương thức này cho thấy người dùng đang gửi dữ liệu từ biểu mẫu web.



Hình ảnh wireshark bắt gói tin và đọc gói tin

3.4.3. Đánh giá rủi ro từ thực nghiệm Ettercap

Việc sử dụng Ettercap chứng minh tính tự động hóa và mức độ nguy hiểm cao của các công cụ tấn công tích hợp. Điểm mù của giao thức Lớp 2 kết hợp với sự bất lực của các ứng dụng chạy trên nền tảng HTTP thuần túy tạo điều kiện cho kẻ tấn công thu

thập thông tin xác thực thụ động, mở đường cho nguy cơ di chuyển ngang (Lateral Movement).

3.5. Thực nghiệm 3: Tấn công Man-in-the-Middle và Sniffing sử dụng khung công cụ Bettercap

3.5.1. Cơ sở lý thuyết và Quy trình thực thi

Bettercap là một framework đánh giá an ninh mạng thế hệ mới, sở hữu kiến trúc mô-đun mạnh mẽ, cho phép thực thi trinh sát, bẻ lái mạng và nghe lén trong một môi trường dòng lệnh tương tác trực quan. Các lệnh cấu hình cơ bản trong Bettercap:

Bash

sudo bettercap -iface eth0

net.probe on

set arp.spoof.targets 192.168.10.20, 192.168.10.10

arp.spoof on

net.sniff on

3.5.2. Trình tự phân tích và Minh chứng Hình ảnh Thực nghiệm

Quá trình thực nghiệm với Bettercap được minh chứng qua 3 bước hình ảnh tuần tự:

Bước 1: Chụp màn hình lệnh chạy tấn công (Bettercap)

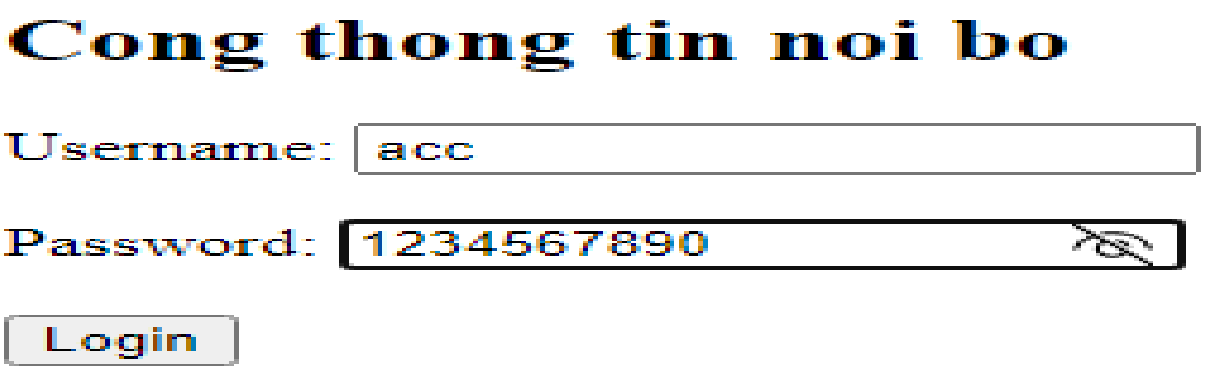
Phân tích kỹ thuật: Cửa sổ Terminal hiển thị phiên làm việc tương tác của Bettercap v2.41.5. Các thông báo log hệ thống xác nhận việc kích hoạt mô-đun trinh sát mạng (net.probe), thiết lập mục tiêu và khởi chạy thành công mô-đun đầu độc ARP (arp.spoof) trong dải mạng 192.168.10.0/24.



Hình ảnh chạy lệnh tấn công Bettercap trên terminal của kali linux

Bước 2: Đăng nhập web HTTP bất kỳ cần nhập user và password (Trích xuất dữ liệu nhạy cảm)

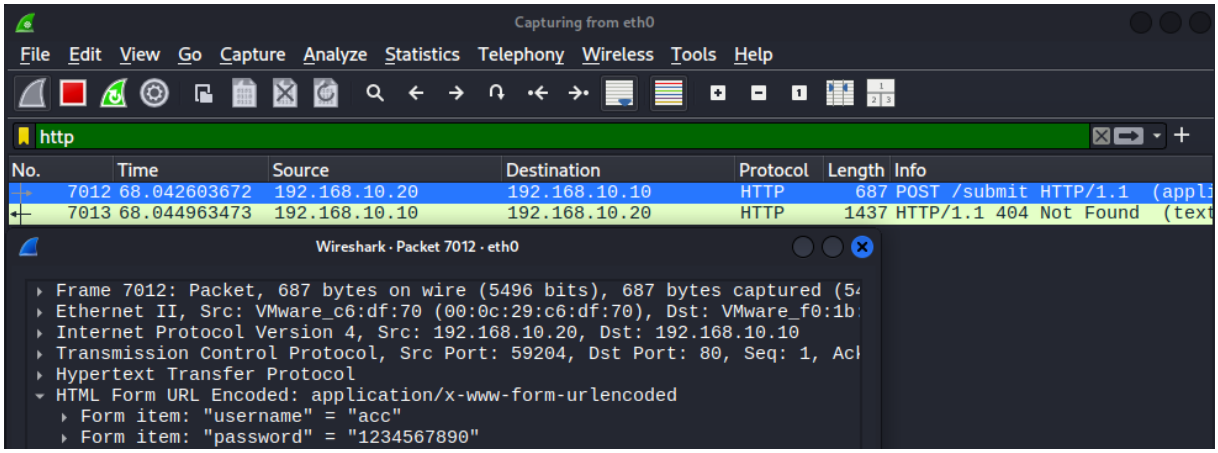
Phân tích kỹ thuật: Bảng thông tin chi tiết tầng ứng dụng (HTML Form URL Encoded) trích xuất trọn vẹn cặp khóa định danh do người dùng nhập trên giao diện web mồi:



Hình ảnh user và password của web HTTP

Bước 3: Chụp màn hình Wireshark bắt gói tin

Phân tích kỹ thuật: Khung làm việc của Wireshark bắt giữ đồng thời các gói tin HTTP luân chuyển qua card mạng eth0, ghi nhận gói tin Frame 15070 mang phương thức POST /submit HTTP/1.1 khi người dùng thực hiện thao tác gửi biểu mẫu từ trình duyệt.



Hình ảnh chạy lệnh tấn công Ettercap trên terminal của kali linux

3.5.3. Đánh giá rủi ro từ thực nghiệm Bettercap

Sự thành công của Bettercap khẳng định mức độ nguy hiểm của các framework tấn công hiện đại, cho phép rút ngắn thời gian chiếm quyền kiểm soát hệ thống. Việc các thiết bị trong mạng LAN ngầm định tin tưởng lẫn nhau ở Lớp 2 kết hợp với ứng dụng nội bộ không mã hóa khiến mật khẩu (1011000) bị đánh cắp dễ dàng, tạo bàn đạp cho các bước leo thang đặc quyền tiếp theo.

3.6. Phân tích so sánh chuyên sâu các công cụ Tấn công MitM Trong khuôn khổ thực nghiệm, ba công cụ (Arpspoof, Ettercap, Bettercap) đã được sử dụng. Dù có chung mục tiêu thao túng Tầng 2, kiến trúc phần mềm và triết lý vận hành của chúng có sự khác biệt rõ rệt, được tổng hợp qua bảng phân tích kỹ thuật sau:

Bảng 3.1: So sánh đặc tính kỹ thuật các công cụ tấn công MitM

Tiêu chí	Arpspoof (dsniff)	Ettercap	Bettercap
Ngôn ngữ cốt lõi	C (Lịch sử phát triển lâu đời)	C / Ncurses	Go (Golang - Hiện đại, đa luồng)
Kiến trúc phần mềm	Tiện ích đơn lẻ (Single-purpose). Chỉ tập trung làm một việc là giả mạo ARP.	Tích hợp (All-in-one). Tích hợp sẵn bộ đánh hơi (Sniffer) và phân tích giao thức.	Khung làm việc (Framework) dạng Mô-đun (Modules). Rất linh hoạt và mạnh mẽ.
Yêu cầu cấu hình	Phải kết hợp cấu hình thủ công (bật ip_forward) và dùng phần mềm thứ ba (Wireshark) để đọc gói tin.	Tự động hóa cao. Tự động chuyển tiếp IP và đọc mật khẩu trực tiếp trên Terminal.	Khởi chạy qua giao diện tương tác (Interactive). Có thể kết nối API và giao diện Web (WebUI).
Khả năng tàng hình (Stealth)	Thấp, phát sinh lượng lớn gói tin Broadcast gây ồn ào trên mạng.	Trung bình. Cung cấp một số bộ lọc bảo vệ chống phát hiện.	Rất cao. Cung cấp các mô-đun thao túng tinh vi, khó bị hệ thống IDS truyền thống phát hiện.
Đánh giá trong CEH	Dùng để minh họa nguyên lý cơ bản nhất của ARP Poisoning.	Dùng trong các bài kiểm tra đánh giá nhanh (Quick Assessment).	Trở thành tiêu chuẩn mới (Industry Standard) cho Red Team trong tấn công mạng LAN.

3.7. Tổng hợp Đánh giá Rủi ro Mạng Truyền thống

Từ kết quả thực nghiệm đồng bộ của ba công cụ (arpspoof, ettercap, và bettercap), báo cáo đúc kết 3 rủi ro cốt lõi của mạng truyền thống:

1. Sự sụp đổ của mô hình Tin cậy Ngầm định: Mạng LAN truyền thống tin tưởng hoàn toàn các thiết bị kết nối bên trong, thiếu cơ chế xác thực Lớp 2 (như bảo mật ARP).
2. Mất mát tính bảo mật trầm trọng: Cho phép kẻ tấn công dễ dàng đánh cắp thông tin định danh của quản trị viên (Admin credentials) dưới dạng văn bản thô.
3. Nguy cơ di chuyển ngang (*Lateral Movement*): Tạo bàn đạp để kẻ tấn công xâm nhập sâu hơn vào các phân vùng hệ thống cốt lõi khác.

3.8. Kết luận Chương 3

Thông qua chuỗi ba bài thực nghiệm sử dụng ba công cụ khác nhau, Chương 3 đã minh chứng rõ ràng và thuyết phục về các điểm yếu chí mạng của kiến trúc mạng truyền thống. Những kết quả thực nghiệm này đặt ra nhu cầu cấp bách phải tái cấu trúc toàn diện hệ thống sang mô hình bảo mật Zero Trust kết hợp Vi phân đoạn (Micro-segmentation) tại Chương 4 để vô hiệu hóa hoàn toàn các nguy cơ trên.

CHƯƠNG 4: TRIỂN KHAI VÀ THỰC NGHIỆM KIẾN TRÚC ZERO TRUST DƯỚI GÓC NHÌN CEH

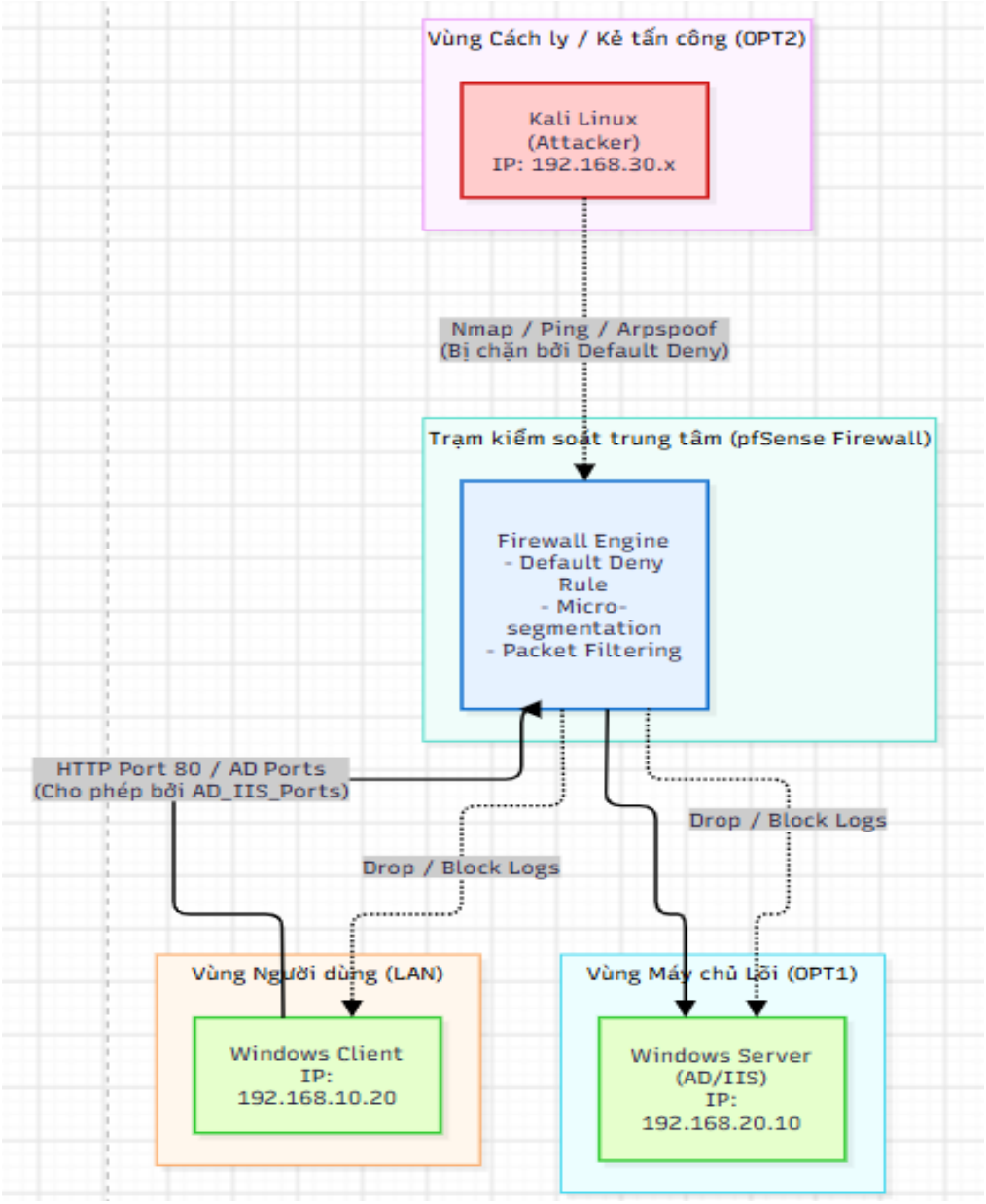
4.1. Sơ đồ mô tả hệ thống và chiến lược phân vùng mạng (Micro-segmentation)

Trong phương pháp luận của Chuyên gia Bảo mật Tấn công (Certified Ethical Hacker - CEH), giai đoạn chuyển đổi từ mạng phẳng truyền thống sang kiến trúc Zero Trust tương đương với việc thiết lập lại toàn bộ ranh giới ảo (*Logical Perimeters*). Hệ thống thực nghiệm được tái cấu trúc thành các vùng độc lập nhằm triệt tiêu hoàn toàn khả năng di chuyển ngang (*Lateral Movement*) của kẻ tấn công:

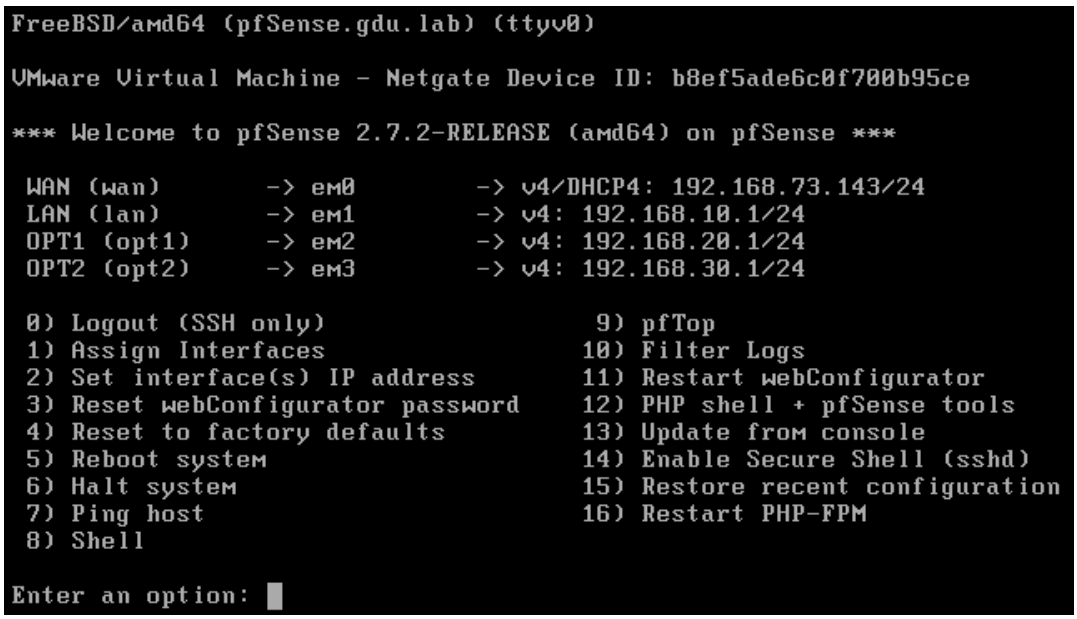
- Phân vùng LAN (Client Zone - 192.168.10.0/24): Khu vực vận hành của các máy trạm người dùng hợp pháp. Dưới góc độ CEH, đây là vùng có bề mặt tấn công (*Attack Surface*) cần được kiểm soát chặt chẽ để ngăn chặn tình trạng máy trạm bị chiếm đoạt và biến thành bàn đạp tấn công nội bộ.
- Phân vùng OPT1 (Server Zone - 192.168.20.0/24): Khu vực chứa các máy chủ cốt lõi (Active Directory, IIS Web Server). Phân vùng này hoạt động như một

vùng tài nguyên cô lập, hoàn toàn không cho phép các kết nối trực tiếp từ ngoài vào nếu không thỏa mãn các chính sách kiểm soát truy cập nghiêm ngặt (Access Control Lists - ACLs).

- Phân vùng OPT2 / Dark Network (Attacker Zone - vmnet14): Vùng mạng giả định dành cho kẻ tấn công (Kali Linux). Tại đây, mọi đặc quyền truyền thông bị tước bỏ triệt để thông qua nguyên tắc Default Deny, biến phân vùng này thành một "mạng tối" không thể định tuyến.



hình mạng Zero Trust chi tiết các phân vùng

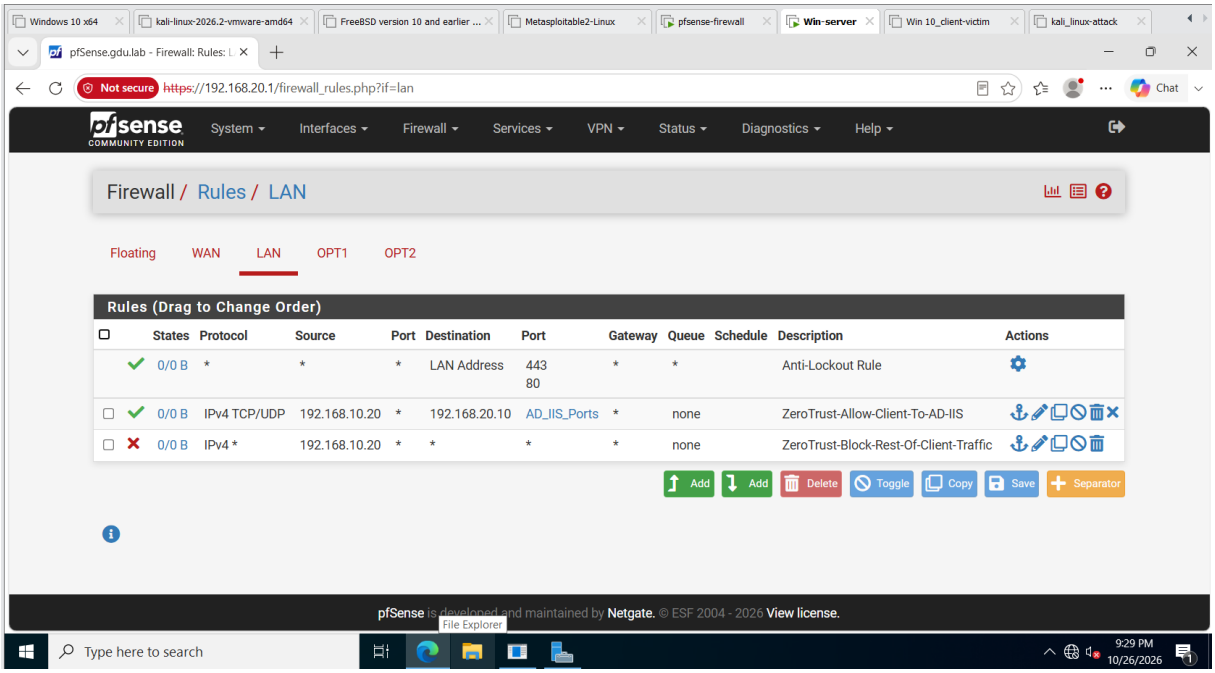


Hình ảnh pfsense phân vùng ra của Zero trust

4.2. Cơ sở lý thuyết phòng thủ chuyên sâu và quy tắc tường lửa pfSense

Theo các tiêu chuẩn bảo mật quốc tế và chương trình đào tạo CEH, kiến trúc Zero Trust phá bỏ hoàn toàn mô hình vành đai cũ (*Perimeter Security*) với châm ngôn cốt lõi: *"Không bao giờ tin tưởng, luôn luôn xác thực" (Never Trust, Always Verify)*.

- Triển khai luật Default Deny (Từ chối mặc định): Mọi gói tin đi qua các cổng của tường lửa pfSense đều bị chặn lại ở trạng thái ban đầu (Block). Chỉ những luồng lưu lượng dữ liệu nào thỏa mãn các quy tắc tường lửa được định nghĩa rõ ràng (*Explicit Allow*) mới được phép thông qua. Điều này ngăn chặn triệt để các lỗ hổng do cấu hình mở (*Misconfiguration*).
- Áp dụng nguyên tắc Đặc quyền tối thiểu (Principle of Least Privilege - PoLP): Hệ thống cấu hình tường lửa chỉ mở các cổng dịch vụ nghiệp vụ thực sự cần thiết (thông qua Alias AD_IIS_Ports bao gồm TCP 80, TCP/UDP 53, TCP 88, TCP/UDP 389, TCP 445). Bất kỳ hành vi quét cổng hay cố gắng kết nối đến các cổng dịch vụ khác đều bị từ chối ngay lập tức.



hình ảnh cấu hình chi tiết Firewall Rules và Alias trên pfSense

4.3. Thực nghiệm kiểm chứng và phân tích hành vi tấn công dưới góc độ CEH

Để chứng minh hiệu quả của kiến trúc phòng thủ, các kịch bản kiểm thử xâm nhập (Penetration Testing) được tái hiện từ góc nhìn của một hacker đứng tại phân vùng cách ly vmnet14.

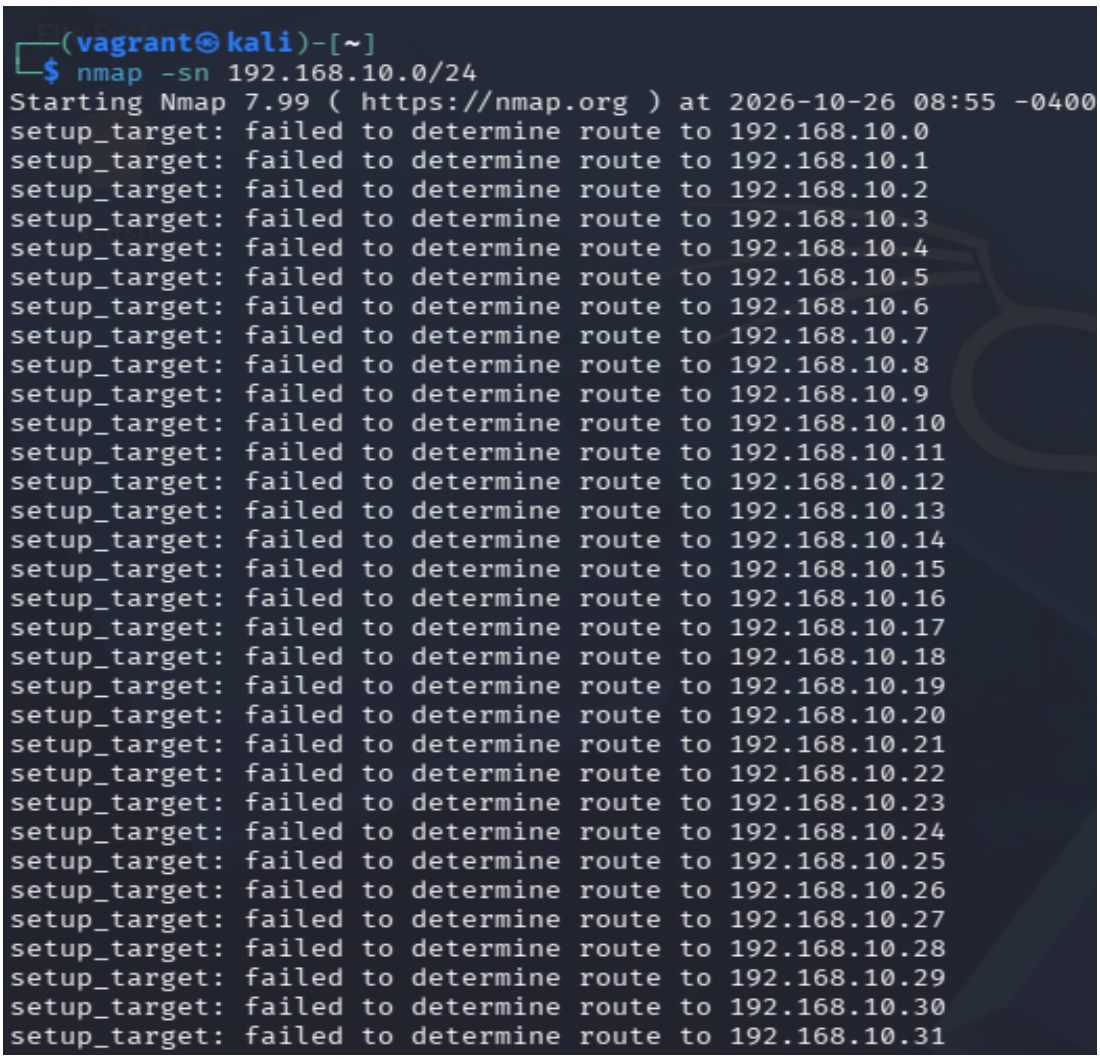
4.3.1. Đánh giá giai đoạn Trinh sát và Quét mạng (Reconnaissance & Scanning)

Trong chuỗi tấn công tiêu chuẩn (Cyber Kill Chain), giai đoạn Reconnaissance và Scanning đóng vai trò tiền đề để kẻ tấn công vẽ ra bản đồ mạng và tìm kiếm điểm yếu.

Thực nghiệm quét mạng: Khi kẻ tấn công từ máy Kali Linux thực hiện lệnh quét nmap -sn 192.168.10.0/24 hoặc kiểm tra kết nối ping, hệ thống trả về thông báo lỗi setup_target: failed to determine route to... và ping: connect: Network is unreachable.

Phân tích chuyên sâu (CEH Perspective):

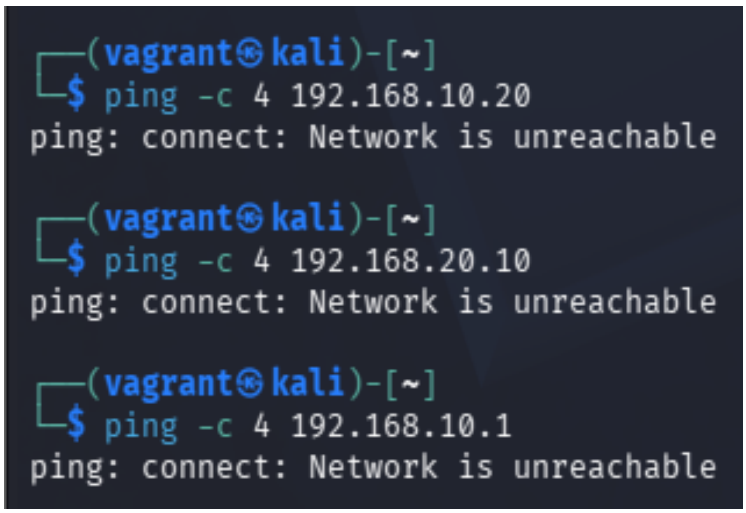
- Ở tầng mạng (Layer 3), tường lửa pfSense từ chối cung cấp bảng định tuyến sang các phân vùng khác.
- Kẻ tấn công rơi vào trạng thái "mù" hoàn toàn (Dark Network). Do không thể định vị được địa chỉ IP hay sự tồn tại của mục tiêu, toàn bộ các bước tiếp theo trong Cyber Kill Chain (như Enumeration và Exploitation) bị khóa chặt ngay từ điểm xuất phát.



hình ảnh kết quả lệnh ping đến Victim bằng Nmap



hình ảnh kết quả lệnh ping đến server để kiểm tra các công bằng Nmap



hình ảnh kết quả lệnh Ping đến 3 máy pfsense, Victim và server

4.3.2. Kiểm thử vô hiệu hóa các công cụ tấn công liên kết dữ liệu (Arpspoof, Ettercap, Bettercap)

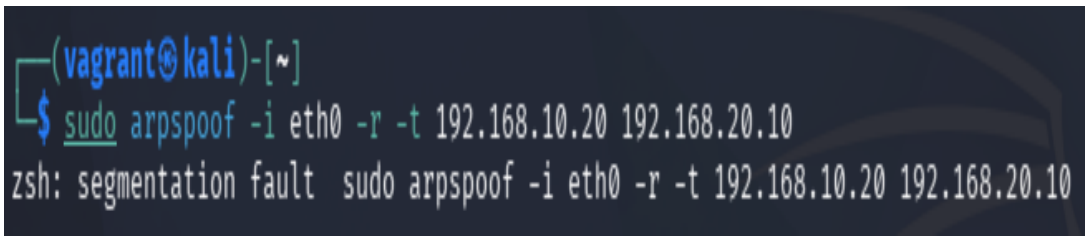
Giao thức ARP (Address Resolution Protocol) hoạt động ở tầng liên kết dữ liệu (Layer 2) và không có cơ chế xác thực bản thân, vốn là điểm yếu cốt lõi bị lợi dụng trong các cuộc tấn công Man-in-the-Middle (MitM) trên mạng phẳng.

Thực nghiệm với Ettercap và Bettercap: Khi kẻ tấn công cố gắng khởi chạy các lệnh giả mạo ARP từ dải mạng cách ly:

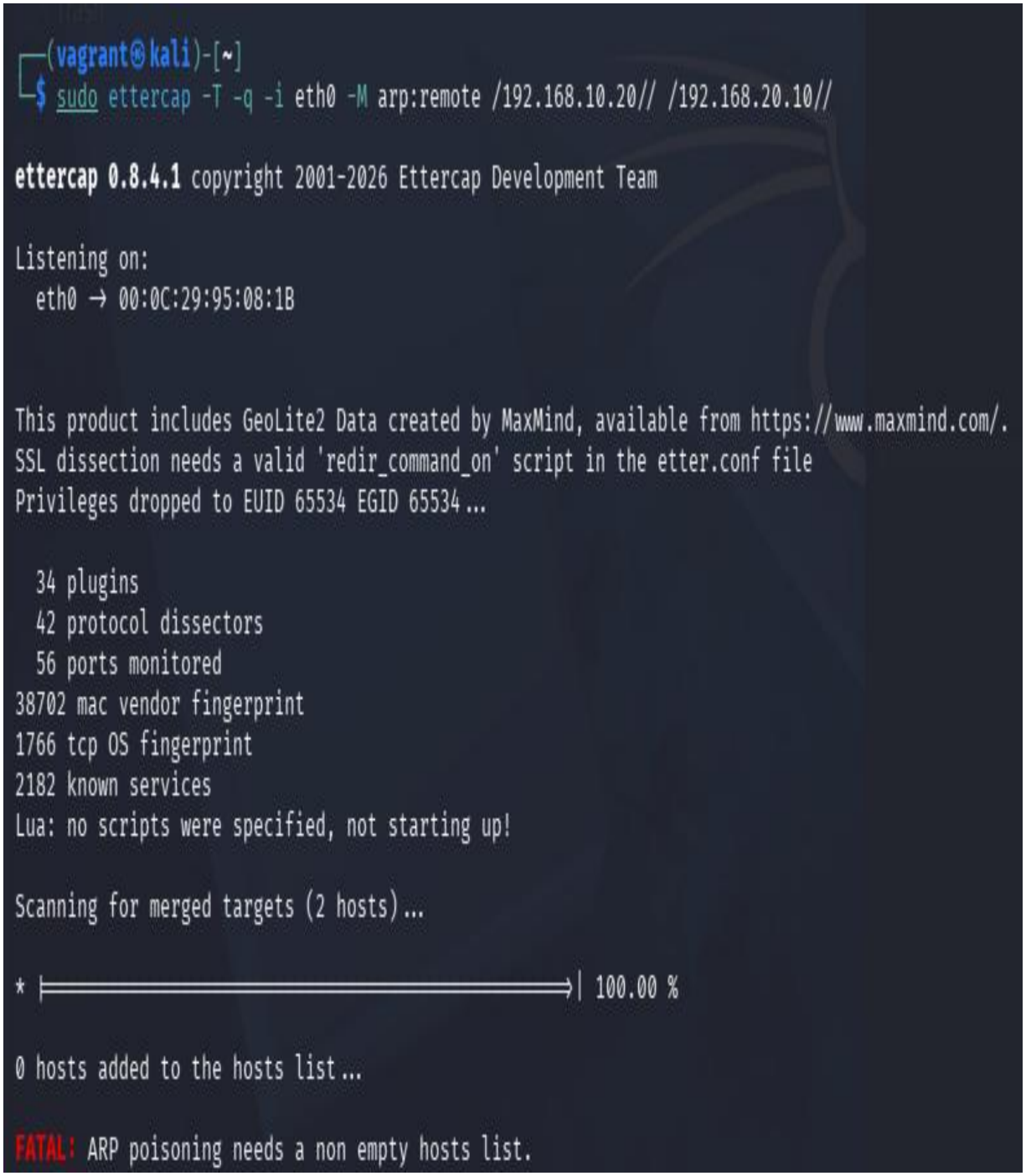
- Arpspoof: báo không hoạt động vì không tìm thấy ip của máy victim
- Ettercap: Báo lỗi FATAL: ARP poisoning needs a non empty hosts list do không thể tìm thấy bất kỳ máy chủ nào trong danh sách mục tiêu.
- Bettercap: Liên tục hiển thị cảnh báo [war] arp.spoof could not find spoof targets trong suốt quá trình chạy.

Phân tích chuyên sâu (CEH Perspective):

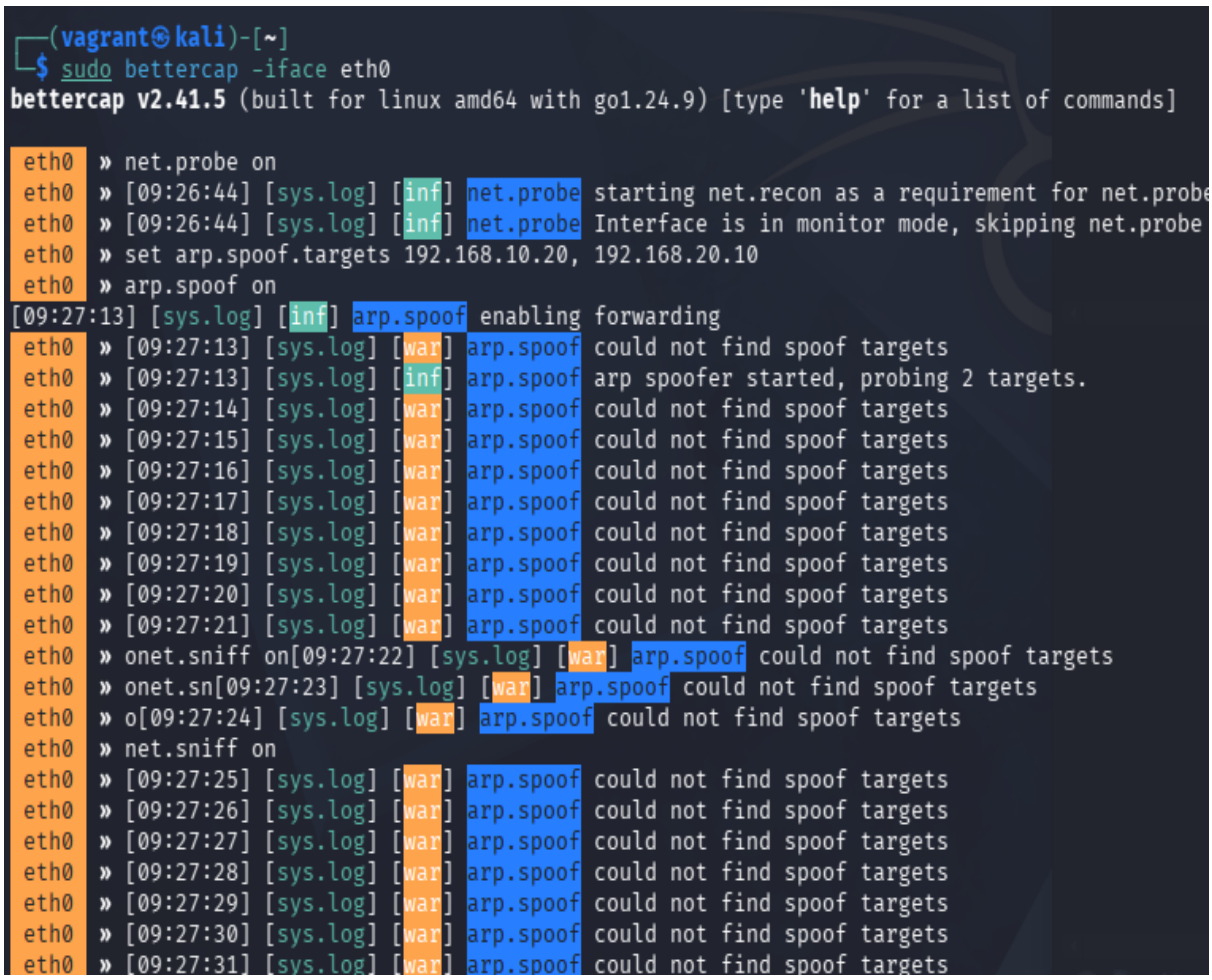
- Các gói tin ARP Request/Reply mang tính chất Broadcast cục bộ bị cô lập hoàn toàn bên trong phân vùng vmnet14.
- Việc áp dụng vi phân đoạn mạng (Micro-segmentation) đã tạo ra một bức tường vô hình ở tầng Layer 2, ngăn chặn tuyệt đối các gói tin đầu độc ARP lan truyền sang các phân vùng chứa Client hoặc Server.



hình ảnh kết quả thực thi thất bại của các công cụ Arpspoof



hình ảnh kết quả thực thi thất bại của các công cụ Ettercap



hình ảnh kết quả thực thi thất bại của các công cụ Bettercap

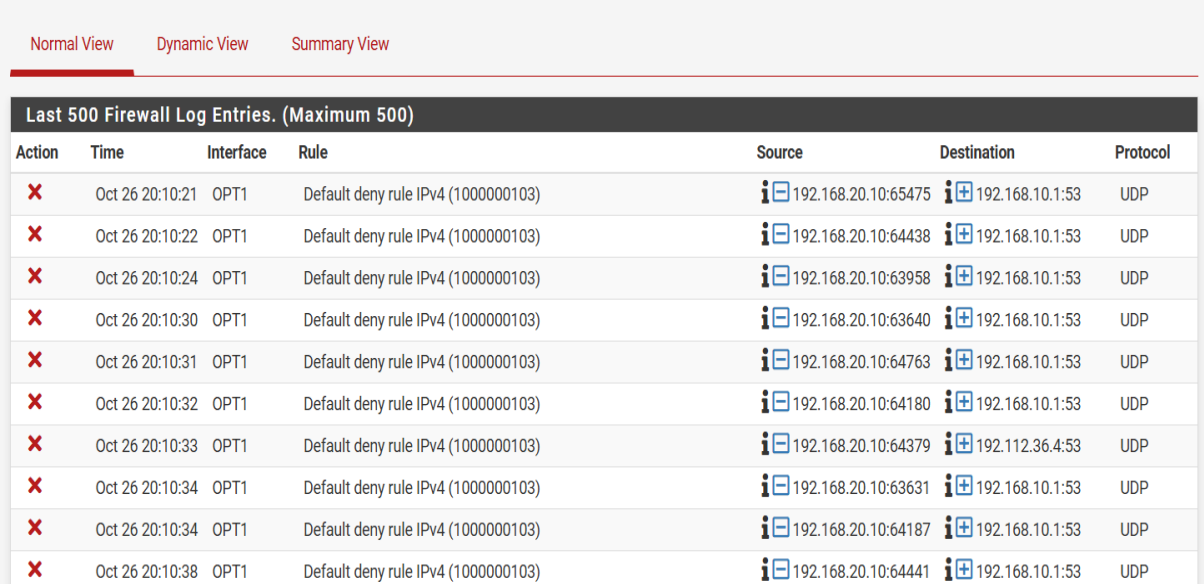
4.3.3. Phân tích Nhật ký giám sát thời gian thực từ Tường lửa (Firewall Audit Trails)

Trong các hoạt động ứng phó sự cố và bảo mật chủ động, hệ thống ghi nhận nhật ký (Log) là minh chứng pháp lý kỹ thuật quan trọng nhất.

Thực nghiệm giám sát: Truy cập vào mục Status > System Logs > Firewall trên giao diện pfSense, hệ thống ghi nhận hàng loạt dòng sự kiện với biểu tượng dấu X màu đỏ (Action: Block), chỉ định rõ ràng các gói tin từ nguồn không được phép cố gắng thăm dò đều bị hủy bỏ lập tức dựa trên Default deny rule.

Phân tích chuyên sâu (CEH Perspective):

- Nhật ký tường lửa cung cấp khả năng hiển thị toàn diện (*Full Visibility*), giúp đội ngũ quản trị an ninh mạng (Blue Team) ngay lập tức phát hiện các dấu hiệu quét cổng, dò tìm hệ thống từ các phân vùng ngoại vi hoặc nội bộ bất thường.



Normal View | Dynamic View | Summary View

Last 500 Firewall Log Entries. (Maximum 500)

Action	Time	Interface	Rule	Source	Destination	Protocol
✘	Oct 26 20:10:21	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:65475	192.168.10.1:53	UDP
✘	Oct 26 20:10:22	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:64438	192.168.10.1:53	UDP
✘	Oct 26 20:10:24	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:63958	192.168.10.1:53	UDP
✘	Oct 26 20:10:30	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:63640	192.168.10.1:53	UDP
✘	Oct 26 20:10:31	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:64763	192.168.10.1:53	UDP
✘	Oct 26 20:10:32	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:64180	192.168.10.1:53	UDP
✘	Oct 26 20:10:33	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:64379	192.112.36.4:53	UDP
✘	Oct 26 20:10:34	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:63631	192.168.10.1:53	UDP
✘	Oct 26 20:10:34	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:64187	192.168.10.1:53	UDP
✘	Oct 26 20:10:38	OPT1	Default deny rule IPv4 (1000000103)	192.168.20.10:64441	192.168.10.1:53	UDP

hình ảnh Firewall Logs hiển thị chi tiết các gói tin bị Block

4.3.4. Phân tích Cơ chế Kiểm tra Gói tin Trạng thái (Stateful Packet Inspection - SPI) trên pfSense

Sự thành công của mô hình Zero Trust trong đồ án phụ thuộc rất lớn vào công nghệ lõi của hệ điều hành pfSense, đó là công cụ Packet Filter (pf) vận hành cơ chế Stateful Packet Inspection (SPI). Khác với các tường lửa thế hệ cũ chỉ kiểm tra gói tin độc lập (Stateless) dựa trên IP/Port, công nghệ SPI trên pfSense hoạt động sâu sát hơn:

- Giám sát toàn bộ phiên (Session Tracking): Khi máy Client (LAN) khởi tạo một kết nối hợp pháp tới Server (OPT1) qua cổng 80 (đã được cho phép trong Alias AD_IIS_Ports), pfSense không chỉ cho gói tin đi qua, mà nó còn tạo ra một "Bản ghi trạng thái" (State Entry) lưu trong bộ nhớ RAM.
- Bắt tay 3 bước (TCP 3-way Handshake): pfSense theo dõi chặt chẽ quá trình bắt tay TCP (SYN, SYN-ACK, ACK). Nếu máy Kali Linux (ở OPT2) cố gắng gửi một gói tin ACK giả mạo hoặc gói tin mang mã độc chèn ngang vào Server mà không đi qua bước khởi tạo SYN hợp lệ ban đầu, pfSense sẽ lập tức rớt (Drop) gói tin đó vì nó không khớp với bất kỳ trạng thái nào trong bảng State Table.
- Tối ưu hiệu năng: Nhờ bảng trạng thái này, các gói tin phản hồi từ Server về Client sẽ tự động được thông qua nhanh chóng mà không cần tường lửa phải đọc lại các luật (Rules) từ đầu đến cuối, giúp mô hình Zero Trust dù có nhiều lớp kiểm soát nhưng không làm nghẽn cổ chai (bottleneck) mạng nội bộ.

4.3.5. Giải phẫu cấu trúc Nhật ký Tường lửa (Firewall Log Anatomy)

- Thông qua hình ảnh minh chứng Firewall Logs (tại mục 4.3.3), dưới góc độ kiểm toán an ninh, các trường dữ liệu mang ý nghĩa pháp lý kỹ thuật sâu sắc:
- Action (Hành động): Biểu tượng chữ X (màu đỏ) đại diện cho trạng thái Block. Theo nguyên tắc Default Deny, tường lửa lập tức hủy gói tin một cách thầm lặng (Drop) mà không phản hồi lại mã lỗi cho kẻ tấn công (giữ nguyên hiệu ứng Dark Network).
- Interface (Giao diện): Xác định rõ vùng mạng (Zone) nào đang bị đe dọa hoặc có hành vi bất thường (ví dụ: OPT1, OPT2).
- Rule (Luật thực thi): Default deny rule IPv4 - Minh chứng rõ ràng nhất cho thấy khi không có luật nào cho phép rõ ràng, hệ thống tự động khóa chặt.
- Source / Destination / Protocol: Ghi nhận chính xác IP kẻ tấn công, IP mục tiêu và giao thức (UDP/TCP). Dữ liệu này là cơ sở quan trọng (Indicators of Compromise - IoC) để tích hợp vào các hệ thống giám sát cảnh báo tập trung (SIEM) trong mô hình bảo mật doanh nghiệp quy mô lớn.

4.4. Kết luận chương

Thông qua quá trình triển khai thực nghiệm và kiểm tra an ninh toàn diện tại chương này, các mục tiêu đề ra của mô hình Zero Trust Architecture (ZTA) tích hợp tường lửa pfSense đã được kiểm chứng một cách thực tế và khách quan theo tiêu chuẩn kiểm định an toàn thông tin (CEH):

1. Hiệu quả của Vi phân đoạn (Micro-segmentation): Việc phân tách rõ ràng các phân vùng mạng (LAN, OPT1, OPT2 tương ứng với các switch ảo vmnet12, vmnet13, vmnet14) đã triệt tiêu hoàn toàn khả năng di chuyển ngang (*Lateral Movement*) của kẻ tấn công. Mọi nỗ lực định tuyến từ vùng độc hại vào vùng lõi đều bị vô hiệu hóa ở tầng Layer 3.

2. Sự thất bại của các kỹ thuật tấn công Lớp 2 (Layer 2 Attacks): Các thử nghiệm tấn công Man-in-the-Middle (MitM) sử dụng các công cụ chuyên sâu như Arpspoof, Ettercap và Bettercap từ máy Kali Linux đã chứng minh rằng: khi không còn chung một miền quảng bá (Broadcast Domain) và bị kiểm soát chặt

chẽ bởi tường lửa, các kỹ thuật đầu độc bảng ARP (ARP Poisoning) hoàn toàn không thể thực hiện được do không thể phân giải địa chỉ MAC của mục tiêu.

3. Tính đắc lực của cơ chế "Từ chối Mặc định" (Default Deny): Nhật ký hệ thống từ pfSense Firewall Logs đã ghi nhận và chặn đứng toàn bộ các gói tin dò quét, trinh sát (Reconnaissance) của kẻ tấn công. Điều này khẳng định triết lý *"Không bao giờ tin tưởng, luôn luôn xác thực"* của Zero Trust đã chuyển hóa thành công hệ thống từ một mạng phẳng dễ bị tổn thương thành một "Mạng tối" (*Dark Network*) đối với các thực thể chưa được định danh.
4. Đảm bảo tính liên tục của nghiệp vụ (Business Continuity): Song song với việc vô hiệu hóa hoàn toàn kẻ tấn công, hệ thống vẫn duy trì thông suốt các kết nối hợp pháp từ người dùng chính thống (Windows Client) đến máy chủ đích thông qua các quy tắc kiểm soát truy cập nghiêm ngặt (AD_IIS_Ports). Điều này chứng minh giải pháp không làm tê liệt hệ thống mà tối ưu hóa sự cân bằng giữa tính bảo mật và tính khả dụng.

CHƯƠNG 5: ĐÁNH GIÁ TOÀN DIỆN, SO SÁNH VÀ KẾT LUẬN CHUYÊN SÂU

5.1. Bảng đối chiếu và so sánh kỹ thuật (Trước và Sau khi áp dụng Zero Trust)

Bảng dưới đây tổng hợp các tiêu chí đánh giá kỹ thuật an toàn thông tin theo chuẩn CEH giữa hai mô hình thử nghiệm:

Tiêu chí đánh giá chuyên sâu	Mô hình Mạng phẳng Truyền thống (vmnet12)	Mô hình Kiến trúc Zero Trust (vmnet14 + pfSense)
Bề mặt tấn công (Attack Surface)	Rộng lớn. Mọi thiết bị nhìn thấy nhau trong cùng một miền quảng bá (Broadcast Domain).	Tối thiểu hóa triệt để các vùng. Các phân vùng bị cô lập độc lập hoàn toàn bằng vi phân đoạn.

Giai đoạn Trinh sát (Reconnaissance)	Kẻ tấn công quét thành công 100% các thiết bị sống, thu thập đầy đủ phiên bản OS và cổng mở. Thu thập được toàn bộ thông tin của người dung khi truy cập web.	Kẻ tấn công hoàn toàn bất lực, không tìm thấy đường đi (Network is unreachable), tạo hiệu ứng mạng tối.
Khả năng tấn công MitM (ARP Spoofing)	Thành công hoàn toàn. Dễ dàng dùng Arpspoof, Ettercap, Bettercap để nghe lén gói tin.	Thất bại tuyệt đối. Công cụ báo lỗi không tìm thấy mục để có thể quét do bị chặn đứng ở ranh giới Layer 2/3.
Bảo vệ tính bảo mật dữ liệu (Confidentiality)	Thấp. Dữ liệu xác thực định danh (Username/Password HTTP) bị bắt trọn dưới dạng Plaintext qua Wireshark.	Tuyệt đối. Luồng tấn công bị bẻ gãy từ bước đầu tiên trong chuỗi tiêu diệt (Kill Chain), giữ an toàn cho dữ liệu.
Duy trì nghiệp vụ doanh nghiệp	Hoạt động lỏng lẻo, dễ bị lan truyền mã độc (Malware/Ransomware) khi một máy bị chiếm.	Vừa bảo mật tối đa, vừa duy trì thông suốt các dịch vụ hợp pháp nhờ quy tắc chọn lọc (AD_IIS_Ports).

5.2. Đánh giá ưu điểm, hạn chế và bài học kinh nghiệm thực tiễn

5.2.1. Ưu điểm vượt trội của giải pháp Zero Trust tích hợp pfSense

1. Vô hiệu hóa hoàn toàn chuyển động ngang (Lateral Movement Prevention): Ngay cả khi kẻ tấn công đã xâm nhập được một thiết bị biên trong mạng, kiến trúc vi phân đoạn ngăn chặn việc mở rộng vùng ảnh hưởng sang các máy chủ chứa dữ liệu nhạy cảm.

2. Triển khai linh hoạt với chi phí tối ưu: Sử dụng nền tảng tường lửa mã nguồn mở pfSense giúp xây dựng hệ thống phòng thủ cấp độ doanh nghiệp mà không đòi hỏi chi phí phần cứng đắt đỏ.
3. Cơ chế kiểm soát truy cập hạt nhân (Granular Access Control): Cho phép quản trị viên định nghĩa chính xác từng luồng dữ liệu dựa trên nguồn, đích, cổng dịch vụ và giao thức thay vì cho phép toàn quyền theo dải mạng.

5.2.2. Thách thức và bài học vận hành thực tế

- Yêu cầu lập kế hoạch mạng chi tiết: Việc phân chia các dải mạng OPT1, OPT2 và LAN đòi hỏi sự am hiểu sâu sắc về sơ đồ luồng dữ liệu của doanh nghiệp để tránh cấu hình quá ngặt nghèo gây gián đoạn các dịch vụ ngầm (như DNS, Kerberos).
- Chi phí quản trị vận hành (Operational Overhead): Hệ thống chính sách tường lửa phức tạp đòi hỏi quy trình kiểm toán (Audit) thường xuyên để cập nhật các quy tắc khi hạ tầng thay đổi.

5.3. Tổng kết và định hướng phát triển đề tài

5.3.1. Kết luận chung

Đề tài *"Nghiên cứu và triển khai kiến trúc Zero Trust phòng chống tấn công nghe lén trên nền tảng pfSense"* đã hoàn thành xuất sắc các yêu cầu đặt ra của một đồ án chuyên ngành An toàn thông tin:

- Xây dựng thành công môi trường mô phỏng tấn công thực tế, làm rõ cơ chế hoạt động và mức độ nguy hiểm của các cuộc tấn công nghe lén trên mạng phẳng.
- Thiết kế, cấu hình và vận hành thành công mô hình phòng thủ theo chuẩn Zero Trust kết hợp vi phân đoạn và tường lửa pfSense.
- Minh chứng bằng thực nghiệm khoa học qua các công cụ kiểm thử xâm nhập tiêu chuẩn CEH, khẳng định hiệu quả cao trong việc bảo vệ hạ tầng mạng trước các mối đe dọa nội bộ.

5.3.2. Hướng phát triển mở rộng trong tương lai

1. Tích hợp hệ thống phát hiện và ngăn chặn xâm nhập thông minh (IDS/IPS): Bổ sung các engine kiểm tra gói tin chiều sâu (Deep Packet Inspection) như Snort hoặc Suricata trên pfSense để tự động phản ứng và black-list IP độc hại ngay khi phát hiện hành vi quét mạng.
2. Mở rộng sang mô hình Zero Trust Network Access (ZTNA): Kết hợp các giải pháp xác thực danh tính người dùng ứng dụng công nghệ mã hóa đường hầm (Micro-tunnels) thay vì chỉ kiểm soát dựa trên vị trí phân vùng mạng cố định.

TÀI LIỆU THAM KHẢO

- U.S. Department of Defense (DoD) Zero Trust Strategy
- DoD Enterprise Zero Trust Reference Architecture (Bộ Quốc phòng Hoa Kỳ)
- NSA Cybersecurity Technical Report: Embracing a Zero Trust Security Model (Cơ quan An ninh Quốc gia Hoa Kỳ - NSA)
- NIST Special Publication 800-207: Zero Trust Architecture (Viện Tiêu chuẩn và Công nghệ Quốc gia Hoa Kỳ - NIST)
- CISA Zero Trust Maturity Model Version 2.0 (Cơ quan An ninh Cơ sở hạ tầng và An ninh Mạng Hoa Kỳ - CISA)